



Πανεπιστήμιο Πειραιώς
Σχολή Τεχνολογιών Πληροφορικής και Τηλεπικοινωνιών
Τμήμα Ψηφιακών Συστημάτων
Π.Μ.Σ. «Κυβερνοασφάλεια και Τεχνολογίες Τεχνητής Νοημοσύνης»

Νομικό Πλαίσιο Ασφάλειας και Απορρήτου

Τεχνολογίες Κατασκοπευτικού Λογισμικού (Spyware Technologies)

Επιβλέποντες Καθηγητές: Κ. Λαμπρινουδάκης - Σ. Γκρίζαλης

Βιτιόν Αντριάννα	andriana_vition@ssl-unipi.gr
Καλαϊτζίδης Ιωάννης	ioannis_kalaitzidis@ssl-unipi.gr
Σπίνουλα Ιωάννα	ioanna_spinoula@ssl-unipi.gr

Πειραιάς
17/06/2026

Περίληψη

Η ραγδαία εξέλιξη των κατασκοπευτικών λογισμικών (spyware) από απλά εργαλεία εμπορικής παρακολούθησης (adware) σε εξελιγμένα κυβερνοόπλα κρατικού επιπέδου (state-sponsored spyware), όπως το Pegasus και το Predator, έχει αναδείξει σοβαρά κενά στις παραδοσιακές στρατηγικές κυβερνοασφάλειας και στα υφιστάμενα νομικά πλαίσια προστασίας της ιδιωτικότητας. Η παρούσα εργασία εξετάζει την πολυδιάστατη αυτή απειλή, αναλύοντας τους μηχανισμούς μόλυνσης, όπως τις zero-click επιθέσεις, και τις προηγμένες τεχνικές anti-forensics που καθιστούν εξαιρετικά δυσχερή τη δικανική ανίχνευση. Μέσα από την αναδρομική τεχνική μελέτη της επίθεσης FORCEDENTRY (CVE-2021-30860) στο iMessage, καταδεικνύεται πώς οι σύγχρονες απειλές παρακάμπτουν τους μηχανισμούς απομόνωσης (sandboxing) εκμεταλλευόμενες ευπάθειες διαχείρισης μνήμης.

Στον αντίποδα αυτής της τεχνικής αποτυχίας, η εργασία προτείνει μια μεθοδολογία προληπτικού (ex-ante) αρχιτεκτονικού σχεδιασμού πληροφοριακών συστημάτων, εστιάζοντας σε ένα Πληροφοριακό Σύστημα Υγείας (EHR). Με οδηγό το Πλαίσιο Ιδιωτικότητας ISO/IEC 29100 και το πρότυπο διαχείρισης ISO/IEC 27701, αναπτύσσεται ένα μοντέλο μηδενικής εμπιστοσύνης (zero trust). Η προστασία των Προσωπικά Αναγνωρίσιμων Πληροφοριών (PII) επιτυγχάνεται μέσω του αυστηρού Ελέγχου Πρόσβασης βάσει Ρόλων (RBAC) -με βάση το θεσμικό παράδειγμα Cap. 625 του Χονγκ Κονγκ- του περιορισμού σκοπού και της ενσωμάτωσης Τεχνολογιών Ενίσχυσης Ιδιωτικότητας (PETs), όπως η ψευδωνυμοποίηση. Η έρευνα καταλήγει στην ανάγκη για μια ριζική αλλαγή υποδείγματος στη μηχανική λογισμικού, όπου η ιδιωτικότητα δεν αποτελεί απλό εργαλείο κανονιστικής συμμόρφωσης, αλλά οργανικό και μαθηματικά αδιαπραγμάτευτο στοιχείο του αρχιτεκτονικού σχεδιασμού του κώδικα.

Περιεχόμενα

1. Εισαγωγή στη ψηφιακή κατασκοπεία και εξέλιξη απειλών	5
1.1 Ορισμός του spyware και διάκριση από άλλα malware	5
1.2 Από τα adware στο state-sponsored spyware	6
1.3 Στόχοι, κίνητρα και το «Ψηφιακό Πανόπτικον»	7
1.4 Η αναγκαιότητα αλλαγής παραδείγματος στην τεχνολογία λογισμικού	8
2. Μηχανισμοί μόλυνσης, αρχιτεκτονική και ψηφιακή δικανική ανίχνευση (forensics)	10
2.1 Social engineering, spear-phishing και επιθέσεις zero-click	10
2.2 Αρχιτεκτονική και τεχνική ανάλυση σύγχρονων απειλών	11
2.2.1 Το οικοσύστημα του Pegasus (NSO Group)	11
2.2.2 Το οικοσύστημα του Predator (Cytrox/Intellexa).....	12
2.3 Τεχνικές επιμονής και αποφυγής εντοπισμού (anti-forensics/memory-only)	12
2.4 Ψηφιακή δικανική ανάλυση (digital forensics) και εργαλεία ανίχνευσης (logs, packet, capture, MVT)	13
2.5 Ανάγκη μετάβασης από την κατασταλτική άμυνα στον οργανικό σχεδιασμό ιδιωτικότητας	14
3. Πλαίσιο ISO/IEC 29100 και η μηχανική απαιτήσεων ιδιωτικότητας	16
3.1 Αλλαγή υποδείγματος (paradigm shift) στην τεχνολογία λογισμικού.....	16
3.2 Εννοιολογική θεμελίωση και ορισμός προσωπικών δεδομένων (PII).....	17
3.3 Δρώντες (actors) και ρόλοι στον κύκλο ζωής του λογισμικού	18
3.4 Οι αρχές ιδιωτικότητας (privacy principles) του ISO 29100 ως φραγμός στη διαρροή δεδομένων	19
3.5 Μηχανική απαιτήσεων και αρχιτεκτονικός σχεδιασμός: Η ενσωμάτωση της ιδιωτικότητας από τον σχεδιασμό (Privacy by Design).....	20
4. Το χάσμα μεταξύ νομικού πλαισίου και τεχνολογικής πραγματικότητας	22

4.1 Τα όρια του Ευρωπαϊκού Δικαίου (GDPR) απέναντι στα State-Sponsored Spyware.....	22
4.1.1 Νομικά κενά και γκρίζες ζώνες στη διάθεση κατασκοπευτικού λογισμικού	23
4.2 Η ανάγκη τεχνολογικής (και όχι μόνο νομικής) θωράκισης του λογισμικού	24
5. Μελέτη Περίπτωσης 1-Ανάλυση ευπαθειών και επανασχεδιασμός πλατφορμών μηνυμάτων (iMessage/FORCEDENTRY)	26
5.1 Περιγραφή σεναρίου και ανατομία της επίθεσης FORCEDENTRY	26
5.1.1 Ιστορικό υπόβαθρο και η εξέλιξη των zero-click επιθέσεων της NSO Group	26
5.1.2 Η ανακάλυψη και το πλαίσιο της επίθεσης FORCEDENTRY	27
5.1.3 Τεχνική ανάλυση και ανατομία του CVE-2021-30860	28
5.2 Ανάλυση αποτυχίας των παραδοσιακών μηχανισμών ασφάλειας.....	29
5.3 Δομικές αναβαθμίσεις ασφαλείας στο iOS 15 και η συσχέτισή τους με το ISO/IEC 29100 και PETs.....	30
6. Μελέτη περίπτωσης 2-Ανάπτυξη ηλεκτρονικού φακέλου υγείας (EHR)	32
6.1 Σχεδιασμός πληροφοριακού συστήματος υγείας έναντι προηγμένων απειλών (zero-click spyware).....	32
6.2 Μοντελοποίηση ρόλων, δικαιωμάτων πρόσβασης (RBAC) και περιορισμός σκοπού βάσει ISO 29100	33
6.3 Ενσωμάτωση τεχνολογιών ενίσχυσης ιδιωτικότητας (PETs) και απο-ταυτοποίηση δεδομένων (de-identification)	34
7. Συμπεράσματα	36
7.1 Προκλήσεις στην πρακτική εφαρμογή των προτύπων ιδιωτικότητας έναντι του εμπορικού κατασκοπευτικού λογισμικού	36
7.2 Ανακεφαλαίωση και μελλοντικές κατευθύνσεις στην τεχνολογία λογισμικού	36
8. Βιβλιογραφία	39
9. Πίνακες απόδοσης όρων	Error! Bookmark not defined.

9.1 Πίνακας απόδοσης όρων (Αγγλικά σε Ελληνικά)**Error!** **Bookmark** **not**
defined.

9.2 Πίνακας απόδοσης όρων (Ελληνικά σε Αγγλικά)**Error!** **Bookmark** **not**
defined.

1. Εισαγωγή στη ψηφιακή κατασκοπεία και εξέλιξη απειλών

1.1 Ορισμός του spyware και διάκριση από άλλα malware

Το spyware αποτελεί ειδική κατηγορία κακόβουλου λογισμικού, η οποία σχεδιάζεται με πρωταρχικό σκοπό τη μυστική συλλογή, παρακολούθηση και διαβίβαση πληροφοριών από μια συσκευή ή ένα πληροφοριακό σύστημα, χωρίς την ουσιαστική γνώση, συναίνεση ή ενεργή συμμετοχή του χρήστη. Σε αντίθεση με άλλες μορφές malware, όπως τα ransomware ή οι καταστροφικοί ιοί, το spyware δεν αποσκοπεί κατ' ανάγκη στη διακοπή λειτουργίας ή στην άμεση βλάβη του συστήματος, αλλά στην όσο το δυνατόν πιο αθόρυβη και παρατεταμένη παρουσία του μέσα στο ψηφιακό περιβάλλον του στόχου. Η επιτυχία του εξαρτάται από την αορατότητά του, διότι όσο λιγότερο γίνεται αντιληπτό τόσο μεγαλύτερο είναι το εύρος και η διάρκεια της πληροφορίας που μπορεί να αποσπάσει.

Η ιδιαιτερότητα του spyware έγκειται στο είδος, στην ευαισθησία και στο βάθος των δεδομένων στα οποία μπορεί να αποκτήσει πρόσβαση. Μέσα από τη λειτουργία του είναι δυνατόν να υποκλαπούν μηνύματα, λίστες επαφών, ιστορικά επικοινωνιών, στοιχεία τοποθεσίας, δεδομένα εφαρμογών, εικόνες, αρχεία, ακόμη και πρότυπα συμπεριφοράς του χρήστη. Η έκταση αυτή σημαίνει ότι δεν πρόκειται για ένα απλό τεχνικό συμβάν κυβερνοασφάλειας, αλλά για προσβολή πολλαπλών πτυχών της ιδιωτικής ζωής, της επικοινωνιακής αυτονομίας και της προσωπικότητας του ατόμου. Στη σύγχρονη βιβλιογραφία και στα ευρωπαϊκά θεσμικά κείμενα, το spyware αντιμετωπίζεται γι' αυτόν ακριβώς τον λόγο ως τεχνολογία βαθιάς παρέμβασης στον πυρήνα των θεμελιωδών δικαιωμάτων [1].

Η διάκριση του spyware από συναφείς τεχνολογίες, όπως το adware ή οι keyloggers, είναι ιδιαίτερα σημαντική τόσο σε τεχνικό όσο και σε νομικό επίπεδο. Το adware συνδέεται κυρίως με πρακτικές εμπορικής παρακολούθησης και στοχευμένης διαφήμισης, ενώ οι keyloggers αφορούν εξειδικευμένα εργαλεία καταγραφής πληκτρολογήσεων. Το spyware, αντιθέτως, συγκροτεί μια ευρύτερη πλατφόρμα επιτήρησης με δυνατότητα συνδυασμένης πρόσβασης σε πολλαπλά επίπεδα του

συστήματος και του ψηφιακού περιβάλλοντος του χρήστη. Αυτή η ποιοτική διαφορά εξηγεί γιατί η μελέτη του δεν περιορίζεται στην κυβερνοασφάλεια, αλλά συνδέεται στενά με το δίκαιο προσωπικών δεδομένων, το απόρρητο των επικοινωνιών και τη θεωρία των ψηφιακών δικαιωμάτων [2]. Επιπροσθέτως, η τεχνική βιβλιογραφία κατηγοριοποιεί το σύγχρονο, πολύπλοκο κατασκοπευτικό λογισμικό (όπως το Pegasus και το Predator) ως εργαλεία «κρατικού επιπέδου» (state-grade spyware), τα οποία διαθέτουν την ικανότητα να προσπερνούν την κρυπτογράφηση των εφαρμογών ανταλλαγής μηνυμάτων, εκμεταλλευόμενα άγνωστες ευπάθειες (zero-day flaws) [3]. Σε αντίθεση με το εμπορικό ή εγκληματικό spyware, ο συγκεκριμένος τύπος λογισμικού είναι σχεδιασμένος ώστε να αποκτά πλήρη και αόρατη πρόσβαση στη συσκευή, εξάγοντας δεδομένα και ελέγχοντας αισθητήρες (κάμερα, μικρόφωνο) σε πραγματικό χρόνο [4].

1.2 Από τα adware στο state-sponsored spyware

Η ιστορική εξέλιξη του spyware αναδεικνύει μια σαφή και σταδιακή μετάβαση από απλές μορφές ανεπιθύμητης εμπορικής παρακολούθησης σε τεχνολογίες υψηλής πολυπλοκότητας με έντονη πολιτική, θεσμική και γεωστρατηγική σημασία. Στα πρώτα στάδια ανάπτυξής του, το λογισμικό παρακολούθησης εμφανιζόταν συχνά ως παραπλανητική προσθήκη σε άλλα προγράμματα ή ως εργαλείο καταγραφής της συμπεριφοράς του χρήστη για εμπορικούς σκοπούς. Ωστόσο, όσο αυξανόταν η αξία των ψηφιακών δεδομένων και η κεντρικότητα των ηλεκτρονικών συσκευών στην καθημερινή ζωή, τόσο μεταβαλλόταν και ο χαρακτήρας των τεχνολογιών αυτών προς πιο αόρατες, πιο επίμονες και πιο επεμβατικές μορφές επιτήρησης.

Η μετάβαση αυτή συνδέεται άμεσα με τον μετασχηματισμό του smartphone σε βασικό κόμβο προσωπικής, επαγγελματικής και κοινωνικής δραστηριότητας. Η σύγχρονη κινητή συσκευή δεν είναι απλώς ένα μέσο επικοινωνίας, αλλά αποθετήριο φωτογραφιών, συνομιλιών, στοιχείων ταυτότητας, πληροφοριών θέσης, οικονομικών συναλλαγών, επαφών, επαγγελματικών εγγράφων και διασυνδέσεων με άλλες ψηφιακές υπηρεσίες [2]. Αυτό σημαίνει ότι η επιτυχής παραβίαση ενός κινητού τηλεφώνου παρέχει στον επιτιθέμενο όχι αποσπασματική πληροφόρηση, αλλά τη δυνατότητα ανασύνθεσης ενός σχεδόν ολοκληρωμένου ψηφιακού προφίλ του χρήστη.

Η συσκευή μετατρέπεται έτσι από καθημερινό εργαλείο επικοινωνίας σε σημείο ολικής έκθεσης της ζωής του υποκειμένου [1].

Μέσα σε αυτό το τεχνολογικό και πολιτικό περιβάλλον αναδείχθηκε το λεγόμενο mercenary ή state-sponsored spyware, δηλαδή λογισμικό υψηλής τεχνολογικής εξειδίκευσης που αναπτύσσεται από ιδιωτικές εταιρείες και διατίθεται ή αξιοποιείται από κρατικούς ή άλλους θεσμικούς φορείς για στοχευμένη επιτήρηση. Κομβικό ορόσημο για αυτή τη μεταστροφή υπήρξε η ανακάλυψη του δικτύου Ghostnet (2009), μίας από τις πρώτες ευρείας κλίμακας εκστρατείες κυβερνοκατασκοπείας, η οποία σηματοδότησε την οριστική μετάβαση του spyware από εργαλείο οικονομικού εγκλήματος σε υπερόπλο γεωπολιτικής επιρροής [5]. Οι περιπτώσεις Pegasus και Predator έδειξαν με ιδιαίτερη σαφήνεια ότι η ψηφιακή κατασκοπεία δεν αποτελεί πλέον αποκλειστικό εργαλείο κρατικών μυστικών υπηρεσιών, αλλά και αντικείμενο διεθνοποιημένης εμπορικής δραστηριότητας. Η ιδιωτικοποίηση αυτή της επιτήρησης επιτείνει τα ζητήματα λογοδοσίας, ελέγχου εξαγωγών, διασυνοριακής ευθύνης και θεσμικής διαφάνειας. Ως εκ τούτου, το spyware δεν είναι απλώς τεχνικό ζήτημα, αλλά φαινόμενο που επηρεάζει ευθέως το κράτος δικαίου και τη λειτουργία της δημοκρατίας [6].

1.3 Στόχοι, κίνητρα και το «Ψηφιακό Πανόπτικον»

Η χρήση spyware δικαιολογείται συχνά από κρατικές αρχές με αναφορά στην ανάγκη πρόληψης ή καταστολής της τρομοκρατίας, του οργανωμένου εγκλήματος και άλλων σοβαρών απειλών κατά της εθνικής ασφάλειας. Ωστόσο, η ευρωπαϊκή θεσμική έρευνα και οι δημόσιες αποκαλύψεις δείχνουν ότι τα συγκεκριμένα εργαλεία έχουν χρησιμοποιηθεί και σε περιπτώσεις που υπερβαίνουν σαφώς αυτό το στενό πεδίο, στρεφόμενα κατά δημοσιογράφων, πολιτικών προσώπων, ακτιβιστών, δικηγόρων, ερευνητών και εκπροσώπων της κοινωνίας των πολιτών. Το στοιχείο αυτό φανερώνει ότι το spyware μπορεί να μετατραπεί από μέσο ασφάλειας σε όργανο επιτήρησης της δημόσιας ζωής, με πιθανές συνέπειες για τον πολιτικό ανταγωνισμό, την ελευθερία του Τύπου και τη δημοκρατική πολυφωνία.

Το spyware, επομένως, δεν λειτουργεί μόνο ως τεχνολογία τεχνικής πρόσβασης σε δεδομένα, αλλά και ως μηχανισμός παραγωγής γνώσης και, μέσω αυτής, παραγωγής ισχύος. Μέσα από την πρόσβαση στο ψηφιακό αποτύπωμα ενός ατόμου, ο χειριστής του spyware μπορεί να χαρτογραφήσει τις σχέσεις, τις επαφές, τα μοτίβα επικοινωνίας, τις πολιτικές ή επαγγελματικές συνδέσεις και γενικότερα το κοινωνικό δίκτυο του στόχου. Με αυτόν τον τρόπο, το spyware επιτρέπει όχι μόνο τη συλλογή πληροφοριών αλλά και την κατανόηση της θέσης του υποκειμένου μέσα σε ευρύτερες δομές επιρροής και αλληλεξάρτησης. Αυτός ακριβώς ο χαρακτήρας το καθιστά εξαιρετικά ισχυρό εργαλείο ελέγχου και παρέμβασης [6].

Η θεωρητική κατανόηση του φαινομένου μπορεί να συνδεθεί με την έννοια του ψηφιακού Πανοπτικού, δηλαδή ενός καθεστώτος στο οποίο η ίδια η δυνατότητα συνεχούς επιτήρησης παράγει πειθαρχικό αποτέλεσμα. Όταν το άτομο γνωρίζει ή εύλογα υποψιάζεται ότι η προσωπική του συσκευή μπορεί να λειτουργεί ως διαρκές εργαλείο παρακολούθησης, ενδέχεται να περιορίσει την επικοινωνία του, να αναθεωρήσει τις επαφές του, να αποφεύγει ορισμένες εκφράσεις και να αυτολογοκριθεί. Έτσι, η ζημία που προκαλεί το spyware δεν περιορίζεται στην παραβίαση απορρήτου, αλλά επεκτείνεται στην αλλοίωση της συμπεριφοράς και στη συρρίκνωση του πεδίου ελεύθερης κοινωνικής και πολιτικής δράσης. Σε αυτή τη βάση, η ψηφιακή κατασκοπεία δεν πλήττει μόνο το άτομο, αλλά και τις ίδιες τις πολιτειακές προϋποθέσεις της δημοκρατικής συμμετοχής [2].

1.4 Η αναγκαιότητα αλλαγής παραδείγματος στην τεχνολογία λογισμικού

Η εμπειρία από τη χρήση εξελιγμένων εργαλείων spyware αναδεικνύει με ιδιαίτερη ένταση τα όρια της παραδοσιακής λογικής κυβερνοασφάλειας. Η αντίληψη σύμφωνα με την οποία η προστασία επιτυγχάνεται κυρίως μέσω εκ των υστέρων ενημερώσεων, αμυντικών εφαρμογών και διορθωτικών μέτρων αποδεικνύεται ανεπαρκής απέναντι σε μηχανισμούς που είναι σύνθετοι, δυσδιάκριτοι και σε ορισμένες περιπτώσεις δεν απαιτούν ούτε καν αλληλεπίδραση του χρήστη [1]. Όταν η επίθεση λαμβάνει χώρα στο παρασκήνιο και η ανίχνευσή της είναι εξαιρετικά δύσκολη, η προστασία της ιδιωτικότητας δεν μπορεί να παραμένει μεταγενέστερη ενέργεια,

πρέπει να αποτελεί συστατικό στοιχείο της αρχιτεκτονικής του συστήματος από το πρώτο στάδιο σχεδιασμού [2].

Το ISO/IEC 29100:2024 παρέχει ένα κρίσιμο θεωρητικό και κανονιστικό πλαίσιο για αυτή τη μετατόπιση. Το πρότυπο ορίζει ένα privacy framework που εισάγει κοινή ορολογία ιδιωτικότητας, προσδιορίζει τους βασικούς ρόλους στην επεξεργασία personally identifiable information (PII) και περιγράφει privacy safeguarding considerations για πληροφοριακά περιβάλλοντα. Παράλληλα, το ίδιο το κείμενο του προτύπου διευκρινίζει ότι εφαρμόζεται σε φυσικά πρόσωπα και οργανισμούς που εμπλέκονται στον σχεδιασμό, την ανάπτυξη, τη δοκιμή, τη συντήρηση, τη διαχείριση και τη λειτουργία ICT systems ή services στα οποία απαιτούνται privacy controls. Επομένως, η ιδιωτικότητα δεν αντιμετωπίζεται εδώ ως περιφερειακή απαίτηση συμμόρφωσης, αλλά ως οργανικό στοιχείο της μηχανικής και της διακυβέρνησης των πληροφοριακών συστημάτων [7].

Υπό το πρίσμα αυτό, η ουσιαστική απάντηση στο spyware δεν μπορεί να εξαντλείται στην καταστολή ή στην ανίχνευση μετά την επίθεση. Απαιτείται σχεδιασμός που να ενσωματώνει την ελαχιστοποίηση δεδομένων, τον σαφή καθορισμό ρόλων και αρμοδιοτήτων, τη διαχείριση του κύκλου ζωής των πληροφοριών και την εφαρμογή συστηματικών privacy controls. Μόνο ένα τέτοιο μοντέλο μπορεί να μειώσει το εύρος των δεδομένων που εκτίθενται, να περιορίσει τις ευκαιρίες καταχρηστικής πρόσβασης και να δημιουργήσει πραγματική ανθεκτικότητα απέναντι σε σύγχρονες μορφές ψηφιακής κατασκοπείας. Με αυτή την έννοια, η αντιμετώπιση του spyware συνιστά ταυτόχρονα τεχνική, θεσμική και αρχιτεκτονική πρόκληση [6].

2. Μηχανισμοί μόλυνσης, αρχιτεκτονική και ψηφιακή δικανική ανίχνευση (forensics)

2.1 Social engineering, spear-phishing και επιθέσεις zero-click

Οι μηχανισμοί μόλυνσης του spyware κινούνται σε ένα ευρύ φάσμα, από σχετικά απλές τεχνικές εξαπάτησης του χρήστη έως εξαιρετικά προηγμένες επιθέσεις που πραγματοποιούνται χωρίς καμία ενεργή συμμετοχή του θύματος. Το social engineering στηρίζεται στην ψυχολογική χειραγώγηση του χρήστη, αξιοποιώντας την εμπιστοσύνη, την περιέργεια, την αίσθηση επείγοντος ή την επίκληση αυθεντίας. Στο πλαίσιο αυτό, το θύμα παρασύρεται να ανοίξει έναν σύνδεσμο, να κατεβάσει ένα αρχείο ή να αλληλεπιδράσει με περιεχόμενο που φαίνεται ασφαλές ή οικείο. Το spear-phishing αποτελεί πιο στοχευμένη εκδοχή αυτής της πρακτικής, καθώς το μήνυμα προσαρμόζεται ειδικά στο επαγγελματικό, κοινωνικό ή προσωπικό προφίλ του στόχου, αυξάνοντας σημαντικά την αποτελεσματικότητα της επίθεσης [8].

Σε ακόμη πιο εξελιγμένο επίπεδο εντάσσονται οι zero-click επιθέσεις, οι οποίες συγκαταλέγονται στις πιο ανησυχητικές μορφές ψηφιακής διείσδυσης. Στις περιπτώσεις αυτές, η μόλυνση μπορεί να πραγματοποιηθεί χωρίς κλικ, χωρίς άνοιγμα συνδέσμου, χωρίς εγκατάσταση αρχείου και χωρίς οποιαδήποτε συνειδητή ενέργεια του χρήστη. Η επιτυχία της επίθεσης εξαρτάται από ευπάθειες στον τρόπο με τον οποίο οι πλατφόρμες, τα λειτουργικά συστήματα και οι εφαρμογές επεξεργάζονται εισερχόμενο περιεχόμενο, όπως μηνύματα ή αρχεία. Αυτό σημαίνει ότι η πηγή του κινδύνου μετατοπίζεται από την εσφαλμένη ανθρώπινη συμπεριφορά στην ίδια την αρχιτεκτονική των πληροφοριακών συστημάτων. Πρόκειται για εξέλιξη που ενισχύει την ανάγκη ενσωμάτωσης της ιδιωτικότητας και της ασφάλειας στον σχεδιασμό του λογισμικού [1]. Σε τεχνικό επίπεδο, οι επιθέσεις zero-click αποτελούν εξαιρετικά πολύπλοκες αλυσίδες εκμετάλλευσης (exploit chains), οι οποίες στοχεύουν κινητά λειτουργικά συστήματα παρακάμπτοντας τα καθιερωμένα μέτρα ασφαλείας, όπως το sandboxing ή το code signing [9]. Λόγω της φύσης τους, αυτού του είδους οι επιθέσεις εκτελούνται αθόρυβα και αφήνουν ελάχιστα έως καθόλου εγκληματολογικά ίχνη (forensic evidence) στη συσκευή του θύματος [10].

2.2 Αρχιτεκτονική και τεχνική ανάλυση σύγχρονων απειλών

2.2.1 Το οικοσύστημα του Pegasus (NSO Group)

Το Pegasus αποτελεί το πλέον γνωστό και εμβληματικό παράδειγμα προηγμένου εμπορικού spyware, καθώς συνδέεται με πολύπλοκες επιθετικές δυνατότητες που επιτρέπουν την παραβίαση κινητών συσκευών και την εξαγωγή των δεδομένων που αποθηκεύονται ή επεξεργάζονται σε αυτές. Η σημασία του δεν εξαντλείται στην τεχνική αρτιότητα της επίθεσης, αλλά έγκειται κυρίως στο ότι καθιστά το ίδιο το κινητό τηλέφωνο μηχανισμό πολυεπίπεδης επιτήρησης. Με την επιτυχή μόλυνση, η συσκευή παύει να λειτουργεί μόνο ως μέσο επικοινωνίας και μετατρέπεται σε σημείο πρόσβασης στην ιδιωτική, επαγγελματική και κοινωνική ζωή του χρήστη.

Η περίπτωση του Pegasus έχει ιδιαίτερη βαρύτητα και σε θεσμικό επίπεδο, διότι καταδεικνύει ότι η ψηφιακή παρακολούθηση αυτού του τύπου δεν αφορά απλώς τη συλλογή μεμονωμένων μηνυμάτων ή δεδομένων. Η πρόσβαση σε επικοινωνίες, εφαρμογές, μεταδεδωμένα, τοποθεσία, αρχεία και λοιπά στοιχεία της συσκευής δημιουργεί σοβαρούς κινδύνους για την ιδιωτικότητα, την προστασία δεδομένων, την ελευθερία έκφρασης, την ελευθερία του Τύπου και εντέλει τη δημοκρατική διαδικασία. Για τον λόγο αυτό, οι μελέτες του Ευρωπαϊκού Κοινοβουλίου αντιμετωπίζουν το Pegasus ως τεχνολογία που επηρεάζει όχι μόνο ατομικά δικαιώματα, αλλά και τις βασικές αξίες πάνω στις οποίες οργανώνεται η δημοκρατική τάξη [8]. Η εμπορευματοποίηση και το επιχειρηματικό μοντέλο διάθεσης της συγκεκριμένης πλατφόρμας ακολουθούν τα πρότυπα του συμβατικού βιομηχανικού λογισμικού. Όπως προκύπτει από το επίσημο εγχειρίδιο περιγραφής του προϊόντος, παρέχεται ως προεπιλογή «ένα έτος υπηρεσιών συντήρησης, υποστήριξης και αναβαθμίσεων» (one year of maintenance, support and upgrades services). Η τεχνική υποστήριξη οργανώνεται σε τρία επίπεδα (three-tier level support): το «Επίπεδο-1 (Tier-1): Τυπικά προβλήματα λειτουργίας του συστήματος», το «Επίπεδο-2 (Tier-2): Προληπτική επίλυση τεχνικών προβλημάτων» με παροχή «απομακρυσμένης βοήθειας με τη χρήση λογισμικού απομακρυσμένης επιφάνειας εργασίας και Εικονικού Ιδιωτικού Δικτύου (VPN)», και το «Επίπεδο-3 (Tier-3): Διόρθωση σφαλμάτων (bug fixing) και ενημερώσεις συστήματος για ουσιαστικές δυσλειτουργίες». Παράλληλα, το πλαίσιο

ανάπτυξης περιλαμβάνει την έκδοση «σημαντικών αναβαθμίσεων (major upgrades) στο σύστημα Pegasus μερικές φορές το χρόνο», με σκοπό την ενσωμάτωση «νέων χαρακτηριστικών» και την «υποστήριξη νέων συσκευών και λειτουργικών συστημάτων» [12].

2.2.2 Το οικοσύστημα του Predator (Cytrox/Intellexa)

Το Predator αποτελεί μία ακόμη εξαιρετικά σημαντική περίπτωση mercenary spyware, διότι ανέδειξε ότι το διεθνές οικοσύστημα ψηφιακής κατασκοπείας δεν περιορίζεται σε μία μόνο εταιρεία ή τεχνολογική πλατφόρμα. Σύμφωνα με τα ευρήματα του Citizen Lab, δύο Αιγύπτιοι στόχοι παραβιάστηκαν με Predator, ενώ στην περίπτωση του Ayman Nour διαπιστώθηκε ταυτόχρονη μόλυνση τόσο με Predator όσο και με Pegasus, τα οποία αποδόθηκαν σε διαφορετικούς κυβερνητικούς πελάτες. Το γεγονός αυτό είναι ιδιαίτερα κρίσιμο, διότι αποκαλύπτει ότι διαφορετικά εργαλεία κατασκοπείας μπορούν να επιχειρούν παράλληλα στο ίδιο πολιτικό και τεχνολογικό περιβάλλον, αυξάνοντας την πολυπλοκότητα της παρακολούθησης και της διερεύνησης [13].

Η σημασία της υπόθεσης Predator δεν είναι μόνο τεχνική αλλά και οικονομικοπολιτική. Η ύπαρξη εταιρικών σχημάτων που αναπτύσσουν, εμπορεύονται και υποστηρίζουν τέτοιες τεχνολογίες φανερώνει ότι η ψηφιακή επιτήρηση έχει ήδη διαμορφώσει ένα ιδιαίτερο πεδίο αγοράς, στο οποίο η τεχνολογική ισχύς συνδέεται άμεσα με ζητήματα λογοδοσίας, εποπτείας και ελέγχου εξαγωγών. Η μελέτη του Predator συμβάλλει έτσι στην κατανόηση όχι μόνο του τρόπου λειτουργίας του spyware, αλλά και της πολιτικής οικονομίας που καθιστά εφικτή τη διάδοσή του. Υπό αυτή την έννοια, το Predator δεν είναι απλώς ένα εργαλείο παραβίασης, αλλά και δείκτης του τρόπου με τον οποίο η τεχνολογία επιτήρησης ενσωματώνεται σε διεθνή δίκτυα ισχύος [13].

2.3 Τεχνικές επιμονής και αποφυγής εντοπισμού (anti-forensics/memory-only)

Η αποτελεσματικότητα των σύγχρονων spyware δεν εξαρτάται αποκλειστικά από την αρχική επιτυχία της παραβίασης, αλλά και από την ικανότητά τους να παραμένουν λειτουργικά ή να αποσπούν δεδομένα χωρίς να εντοπίζονται εύκολα. Για τον λόγο αυτό, τα εργαλεία αυτά συνδέονται με τεχνικές απόκρυψης, περιορισμού ίχνων, ελαχιστοποίησης του εμφανώς κακόβουλου αποτυπώματος και γενικότερης δυσχέρασης της τεχνικής ανάλυσης. Η απόκρυψη αυτή έχει πρακτική αξία, επειδή μειώνει την πιθανότητα έγκαιρης ανίχνευσης και επιτρέπει μεγαλύτερη διάρκεια ή αποτελεσματικότητα της παρακολούθησης. Παράλληλα, καθιστά σαφές ότι το spyware δεν σχεδιάζεται μόνο για να εισέλθει σε ένα σύστημα, αλλά και για να συντηρεί μια συνθήκη αόρατης παρουσίας [8].

Η δυσκολία εντοπισμού έχει ιδιαίτερη σημασία και σε αποδεικτικό επίπεδο. Η απουσία ενός σταθερού, άμεσα ανακτήσιμου ή εύκολα ορατού τεκμηρίου δεν σημαίνει κατ' ανάγκη ότι η παραβίαση δεν συνέβη, αλλά μπορεί να αποτελεί ακριβώς ένδειξη της τεχνολογικής ωριμότητας της επίθεσης. Αυτό καθιστά αναγκαία μια πιο σύνθετη λογική αξιολόγησης των ενδείξεων, στην οποία η έλλειψη εμφανών artefacts δεν ερμηνεύεται αυτομάτως ως απουσία απειλής. Στις υποθέσεις spyware, η τεχνική έρευνα και η νομική κρίση οφείλουν επομένως να λαμβάνουν υπόψη τη δυνατότητα ύπαρξης anti-forensics χαρακτηριστικών και μηχανισμών αποφυγής εντοπισμού [8]. Η δυσκολία αυτή επιτείνεται από ενσωματωμένους μηχανισμούς αυτοκαταστροφής (self-destruct mechanisms) και απόκρυψης (obfuscation). Για παράδειγμα, εάν το λογισμικό ανιχνεύσει την παρουσία εργαλείων ψηφιακής δικανικής ανάλυσης ή διαπιστώσει κάποια κρίσιμη αλλαγή στο περιβάλλον (όπως η αλλαγή της κάρτας SIM), δύναται να διαγράψει τον εαυτό του, να αλλοιώσει τα σχετικά αρχεία καταγραφής (logs) ή ακόμη και να αντικαταστήσει τμήματα της μνήμης με μηδενικά bytes (null bytes) [14].

2.4 Ψηφιακή δικανική ανάλυση (digital forensics) και εργαλεία ανίχνευσης (logs, packet, capture, MVT)

Η ψηφιακή δικανική ανάλυση σε υποθέσεις spyware κινητών συσκευών αποτελεί ένα από τα πιο απαιτητικά πεδία της σύγχρονης κυβερνοασφάλειας. Τα σχετικά τεκμήρια είναι συχνά αποσπασματικά, χρονικά ασταθή, τεχνικά πολύπλοκα και διασκορπισμένα σε διαφορετικά επίπεδα λογισμικού, εφαρμογών και δικτυακών

επικοινωνιών. Για τον λόγο αυτό, η διερεύνηση στηρίζεται σε συνδυασμό μεθόδων, όπως η μελέτη αρχείων καταγραφής, η ανάλυση αντιγράφων ασφαλείας, η αναζήτηση δικτυακών δεικτών και η χρονική συσχέτιση επιμέρους γεγονότων. Η αξία της μεθοδολογίας αυτής δεν βρίσκεται μόνο στην ανίχνευση ενός «κακόβουλου αρχείου», αλλά στη σύνθεση τεχνικών ενδείξεων που καθιστούν πιθανή ή αποδεικτέα την ύπαρξη παραβίασης. Καθώς τα παραδοσιακά λογισμικά προστασίας (antivirus) συνήθως αποτυγχάνουν να εντοπίσουν αυτές τις απειλές, η ψηφιακή εγκληματολογία βασίζεται καθοριστικά σε εξειδικευμένα εργαλεία, όπως το Mobile Verification Toolkit (MVT), το οποίο αυτοματοποιεί την ανάλυση κρυπτογραφημένων αντιγράφων ασφαλείας αναζητώντας ύποπτα ίχνη (Indicators of Compromise) [16]. Επιπλέον, η ανάλυση της δικτυακής κίνησης (packet capture) σε συνδυασμό με τον εντοπισμό ανωμαλιών στη συμπεριφορά των εφαρμογών –όπως η απρόσμενη κατανάλωση μπαταρίας ή η αδικαιολόγητη ενεργοποίηση της κάμερας– διαδραματίζουν κρίσιμο ρόλο στην αποκάλυψη της μόλυνσης [16].

Η σημασία της ψηφιακής δικανικής ανάλυσης δεν είναι μόνο τεχνική αλλά και θεσμική. Τα ευρήματά της μπορούν να αποτελέσουν τη βάση για δημόσια λογοδοσία, ανεξάρτητη θεσμική έρευνα, δικαστικό έλεγχο και αξιολόγηση πιθανών παραβιάσεων θεμελιωδών δικαιωμάτων. Κατ' αυτόν τον τρόπο, η ψηφιακή δικανική λειτουργεί ως γέφυρα ανάμεσα στην τεχνολογική γνώση, την απόδειξη και τη θεσμική προστασία της δημοκρατίας. Ειδικά σε περιβάλλοντα όπου η παρακολούθηση είναι δυσδιάκριτη και οι αποδείξεις περιορισμένες, η σημασία της αυξάνεται ακόμη περισσότερο, διότι αποτελεί έναν από τους λίγους μηχανισμούς που μπορούν να αποκαταστήσουν διαφάνεια και λογοδοσία [17]. Επιπλέον, κατά τη διαδικασία εξέτασης στοχοποιημένων ατόμων από εξειδικευμένα εργαστήρια ψηφιακής εγκληματολογίας (Digital Forensics Labs), η τεχνική διερεύνηση πλαισιώνεται από συγκεκριμένα ερωτήματα τεκμηρίωσης, όπως: «Πότε παρατηρήσατε για πρώτη φορά ότι κάτι δεν πήγαινε καλά; Τι παρατηρήσατε; Τι κάνατε σε εκείνο το σημείο;» καθώς και «Είχατε λάβει κάποιες προφυλάξεις στο διαδίκτυο πριν από αυτή την επίθεση;» [18].

2.5 Ανάγκη μετάβασης από την κατασταλτική άμυνα στον οργανικό σχεδιασμό ιδιωτικότητας

Τα χαρακτηριστικά των σύγχρονων spyware απειλών καταδεικνύουν ότι η αμυντική στρατηγική δεν μπορεί να βασίζεται αποκλειστικά στην εκ των υστέρων ανίχνευση ή αποκατάσταση. Όταν οι επιθέσεις είναι αθέατες, βαθιά επεμβατικές και ενίοτε zero-click, η προστασία δεν μπορεί να εξαρτάται μόνο από εργαλεία εντοπισμού ή από καθυστερημένες διορθωτικές παρεμβάσεις. Απαιτείται μοντέλο στο οποίο η ιδιωτικότητα και η ασφάλεια αντιμετωπίζονται ως οργανικά στοιχεία του ίδιου του συστήματος, ήδη από τη φάση της αρχιτεκτονικής σύλληψης [19].

Το ISO/IEC 29100:2024 στηρίζει ακριβώς αυτή τη λογική, καθώς περιγράφει ένα privacy framework εφαρμόσιμο σε οργανισμούς και φυσικά πρόσωπα που σχεδιάζουν, αναπτύσσουν, συντηρούν ή λειτουργούν ICT systems ή services όπου απαιτούνται privacy controls για την επεξεργασία PII. Η άμυνα απέναντι στο spyware πρέπει έτσι να θεμελιώνεται σε privacy safeguarding requirements, privacy policies, σαφή κατανομή ρόλων και συστηματικά privacy controls [20].

3. Πλαίσιο ISO/IEC 29100 και η μηχανική απαιτήσεων ιδιωτικότητας

3.1 Αλλαγή υποδείγματος (paradigm shift) στην τεχνολογία λογισμικού

Η παραδοσιακή προσέγγιση στην ασφάλεια πληροφοριών επικεντρωνόταν διαχρονικά στην περιμετρική προστασία των συστημάτων, η οποία βασίζεται στην εγκατάσταση τειχών προστασίας (firewalls), συστημάτων ανίχνευσης εισβολών και προγραμμάτων antivirus στα σύνορα του δικτύου με σκοπό τη δημιουργία ενός «οχυρού» γύρω από τις υποδομές. Αυτό το μοντέλο υποθέτει ότι η απειλή βρίσκεται αποκλειστικά έξω από το δίκτυο, όμως η έλευση εξελιγμένων επιθέσεων, όπως τα zero-click spyware (π.χ. Pegasus), απέδειξε ότι οι εισβολείς μπορούν να εισχωρήσουν απευθείας στο εσωτερικό του δικτύου εκμεταλλευόμενοι άγνωστες ευπάθειες, καθιστώντας την περιμετρική άμυνα ξεπερασμένη. Για τον λόγο αυτό, η τεχνολογία λογισμικού απαιτεί μια ριζική αλλαγή υποδείγματος (paradigm shift) και στρέφεται προς το διεθνές πρότυπο ISO/IEC 29100 [7]. Η μετάβαση στο πλαίσιο του ISO 29100 δεν αποτελεί μια απλή προσθήκη νέων εργαλείων ασφάλειας, αλλά μια θεμελιώδη αναθεώρηση του τρόπου με τον οποίο οι οργανισμοί αντιλαμβάνονται και προστατεύουν τα πληροφοριακά τους συστήματα, θέτοντας τον έλεγχο και τη διακυβέρνηση της πληροφορίας στο επίκεντρο του κύκλου ζωής ανάπτυξης λογισμικού [21].

Στο παραδοσιακό μοντέλο ασφάλειας, η βασική μέριμνα ήταν η προστασία των «περιουσιακών στοιχείων πληροφοριών» (Information Assets), ένας όρος που περιλαμβάνει servers, βάσεις δεδομένων, δίκτυα και οποιαδήποτε πληροφορία έχει αξία για τον οργανισμό, με κύριο στόχο τη διασφάλιση της επιχειρησιακής συνέχειας [22]. Αντίθετα, η μηχανική της ιδιωτικότητας (Privacy Engineering) αλλάζει ριζικά αυτό το σκεπτικό. Το κέντρο βάρους μετατοπίζεται από τα περιουσιακά στοιχεία του οργανισμού στις «προσωπικά αναγνωρίσιμες πληροφορίες» (Personally Identifiable Information-PII), δηλαδή στα δεδομένα που αφορούν και μπορούν να ταυτοποιήσουν το ίδιο το φυσικό πρόσωπο (PII Principal) [23]. Το όλο σκεπτικό της μηχανικής της ιδιωτικότητας βασίζεται στην παραδοχή ότι η παραβίαση της ασφάλειας είναι πλέον μια αναπόφευκτη πραγματικότητα, επομένως η προστασία πρέπει να είναι

ενσωματωμένη (by design) στην ίδια την αρχιτεκτονική του λογισμικού και στον τρόπο διαχείρισης των PII, ώστε η πληροφορία να παραμένει ασφαλής ακόμη και αν η υποδομή καταρρεύσει ή μολυνθεί.

Στο νέο αυτό υπόδειγμα, οι κλασικοί έλεγχοι ασφάλειας εξελίσσονται σε εξειδικευμένους «ελέγχους ιδιωτικότητας» (Privacy Controls), οι οποίοι αποτελούν τεχνικά, διοικητικά ή οργανωτικά μέτρα (όπως η ψευδωνυμοποίηση, η κρυπτογράφηση point-to-point και ο αυστηρός περιορισμός πρόσβασης) που εφαρμόζονται απευθείας πάνω στη ροή των δεδομένων για τον μετριασμό των κινδύνων [24]. Το υπόδειγμα αυτό ουσιαστικά ορίζει την αρχιτεκτονική μορφή που πρέπει να υιοθετήσει ένα σύστημα. Μια δομή zero trust (μηδενικής εμπιστοσύνης), η οποία διαχειρίζεται τα δεδομένα με τέτοιο τρόπο ώστε, ακόμη και αν μια τερματική συσκευή μολυνθεί από κάποιον κίνδυνο ιδιωτικότητας (Privacy Risk) ή υποστεί παραβίαση (Privacy breach), η ζημιά να απομονώνεται και τα ευαίσθητα δεδομένα να μην εκτίθενται [25]. Για τον μηχανισμό λογισμικού, η σχέση του με το νέο υπόδειγμα είναι άμεση, καθώς επηρεάζεται βαθύτατα από τον επανακαθορισμό των στόχων του. Οι αρχικοί στόχοι της παραδοσιακής ασφάλειας, που ήταν απλώς η διατήρηση των αντικειμενικών στόχων ελέγχου (Control Objectives) για τη θωράκιση της υποδομής, αντικαθίστανται ή συμπληρώνονται πλέον από τις «απαιτήσεις διασφάλισης της ιδιωτικότητας» (Privacy safeguarding requirements) [26]. Για να είναι το σύστημα ακόμη πιο ασφαλές σήμερα σε σύγκριση με το παρελθόν, οι τελικοί στόχοι του λογισμικού πρέπει να μετατραπούν από παθητικοί (αντίδραση μετά την επίθεση) σε ενεργητικούς και οργανικούς (προληπτικός σχεδιασμός), διασφαλίζοντας ότι η διαχείριση κινδύνου ιδιωτικότητας (Privacy risk management) εκτελείται συνεχώς σε κάθε στάδιο του κώδικα, εξουδετερώνοντας την ικανότητα των spyware να υποκλέπτουν χρήσιμες πληροφορίες [27].

3.2 Εννοιολογική θεμελίωση και ορισμός προσωπικών δεδομένων (PII)

Η θεμελίωση της προστασίας της ιδιωτικότητας στην τεχνολογία λογισμικού προϋποθέτει τον ακριβή προσδιορισμό του αντικειμένου προστασίας, το οποίο στο πλαίσιο του ISO/IEC 29100 ορίζεται ως προσωπικά αναγνωρίσιμες πληροφορίες (Personally Identifiable Information-PII) [28]. Σύμφωνα με το επίσημο διεθνές

πρότυπο, ως PII νοείται κάθε πληροφορία η οποία είτε μπορεί να χρησιμοποιηθεί για την ταυτοποίηση του φυσικού προσώπου στο οποίο αναφέρεται, είτε είναι ή ενδέχεται να συνδεθεί άμεσα ή έμμεσα με αυτό [29]. Το φυσικό πρόσωπο στο οποίο αναφέρονται αυτές οι πληροφορίες ορίζεται αυστηρά ως το υποκείμενο των PII (PII principal) [30]. Κατά τον αρχιτεκτονικό σχεδιασμό πληροφοριακών συστημάτων, το υποκείμενο αυτό αποτελεί την κεντρική οντότητα αναφοράς, της οποίας τα δικαιώματα και το απόρρητο πρέπει να διασφαλίζονται οργανικά μέσα από τη δομή του κώδικα [23].

Για τον μηχανικό λογισμικού, η κατανόηση του εύρους αυτού του ορισμού είναι καθοριστική, καθώς η έμμεση ταυτοποίηση περιλαμβάνει δεδομένα που συχνά θεωρούνται εσφαλμένα ως απλά τεχνικά μεταδεδομένα. Προκειμένου να προσδιοριστεί εάν ένα υποκείμενο PII είναι αναγνωρίσιμο, πρέπει να λαμβάνονται υπόψη όλα τα μέσα που είναι εύλογο να χρησιμοποιηθούν από τον υπεύθυνο επεξεργασίας ή οποιοδήποτε άλλο πρόσωπο για την ταυτοποίησή του [31]. Στοιχεία όπως οι διευθύνσεις IP, τα μοναδικά αναγνωριστικά συσκευών (device fingerprints), τα αρχεία καταγραφής τοποθεσίας (GPS logs) και τα μεταδεδομένα δικτυακής κίνησης εμπίπτουν πλήρως στην κατηγορία των PII, καθώς μπορούν να συνδυαστούν και να οδηγήσουν στην έμμεση αποκάλυψη της ταυτότητας του χρήστη.

Η εννοιολογική αυτή διεύρυνση αποκτά κρίσιμη σημασία κατά την αντιμετώπιση εξελιγμένων κατασκοπευτικών λογισμικών (spyware), καθώς η ψηφιοποίηση των διαδικασιών και η επέκταση των τεχνολογιών πληροφορικής και επικοινωνιών δημιουργούν διαρκώς νέους κινδύνους για την προστασία των PII [32]. Τα σύγχρονα κρατικά spyware δεν περιορίζονται στην υποκλοπή προφανών αρχείων, αλλά λειτουργούν ως μηχανισμοί μαζικής συλλογής συμπεριφορικών δεδομένων, αντλώντας διαρκώς στοιχεία τηλεμετρίας και αισθητήρων. Για τον λόγο αυτό, οι παραδοσιακοί στόχοι ασφάλειας πρέπει να αναθεωρηθούν, καθώς οι έλεγχοι προστασίας μπορεί να είναι οικονομικοί, οργανωτικοί, νομικοί, τεχνικοί, διαδικαστικοί ή εννοιολογικοί, παρέχοντας ένα πλαίσιο υψηλού επιπέδου για τη θωράκιση των PII εντός των πληροφοριακών συστημάτων [21].

3.3 Δρώντες (actors) και ρόλοι στον κύκλο ζωής του λογισμικού

Κατά τον σχεδιασμό και την ανάπτυξη πληροφοριακών συστημάτων με γνώμονα την ιδιωτικότητα, είναι απαραίτητο να προσδιοριστούν εκ των προτέρων όλες οι οντότητες που έχουν έννομο ενδιαφέρον, οι οποίες ορίζονται ως ενδιαφερόμενα μέρη για την ιδιωτικότητα (privacy stakeholders) [33]. Στον πυρήνα αυτών των ενδιαφερόμενων μερών βρίσκεται το υποκείμενο των PII (PII principal), δηλαδή το φυσικό πρόσωπο στο οποίο αναφέρονται οι προσωπικά αναγνωρίσιμες πληροφορίες [30]. Την κεντρική ευθύνη για τη λήψη αποφάσεων σχετικά με τη διαχείριση της πληροφορίας φέρει ο υπεύθυνος επεξεργασίας PII (PII controller), ο οποίος καθορίζει τους επιδιωκόμενους σκοπούς και τα μέσα της επεξεργασίας προσωπικών δεδομένων [34].

Από την άλλη πλευρά, η τεχνική υλοποίηση της επεξεργασίας αυτής ανατίθεται συχνά στον εκτελούντα την επεξεργασία PII (PII processor), ο οποίος επεξεργάζεται τις πληροφορίες αυστηρά για λογαριασμό και σύμφωνα με τις οδηγίες του υπευθύνου επεξεργασίας [35]. Επιπλέον, η αρχιτεκτονική του λογισμικού πρέπει να προβλέπει και να ελέγχει τη ροή πληροφοριών προς οποιοδήποτε τρίτο μέρος (third party), το οποίο αντιπροσωπεύει κάθε ενδιαφερόμενο μέρος για την ιδιωτικότητα εκτός από το υποκείμενο, τον υπεύθυνο και τον εκτελούντα την επεξεργασία [36].

Η αυστηρή απομόνωση αυτών των ρόλων στον κώδικα και στα δικαιώματα πρόσβασης (access control) είναι θεμελιώδους σημασίας για τη θωράκιση του συστήματος. Εάν ένα εξελιγμένο κατασκοπευτικό λογισμικό (spyware) μολύνει τη συσκευή ενός τελικού χρήστη, η απουσία διακριτών ρόλων και περιορισμών θα επέτρεπε στο κακόβουλο λογισμικό να υποκλέψει καθολικά δικαιώματα και να αποκτήσει μη εξουσιοδοτημένη πρόσβαση σε ολόκληρο το οικοσύστημα επεξεργασίας δεδομένων, παραβιάζοντας τη ροή μεταξύ controllers και processors.

3.4 Οι αρχές ιδιωτικότητας (privacy principles) του ISO 29100 ως φραγμός στη διαρροή δεδομένων

Η πρακτική θωράκιση ενός πληροφοριακού συστήματος έναντι της διαρροής δεδομένων που προκαλείται από εξελιγμένα κατασκοπευτικά λογισμικά βασίζεται στην ενσωμάτωση των έντεκα (11) αρχών ιδιωτικότητας (privacy principles) που θεσπίζει το υπόδειγμα ISO/IEC 29100 [37]. Οι αρχές αυτές δεν αποτελούν απλές

θεωρητικές κατευθύνσεις, αλλά μεταφράζονται σε συγκεκριμένα αρχιτεκτονικά αντίμετρα, ξεκινώντας από τις αρχές της συγκατάθεσης και επιλογής (consent and choice) και της νομιμότητας και καθορισμού σκοπού (purpose legitimacy and specification), οι οποίες διασφαλίζουν ότι η ροή επεξεργασίας περιορίζεται αυστηρά και αποκλειστικά στους αντικειμενικούς στόχους που έχει εγκρίνει εκ των προτέρων το υποκείμενο [38].

Καθοριστικό ρόλο στην τεχνική αναχαίτιση των spyware διαδραματίζουν οι αρχές του περιορισμού συλλογής (collection limitation) και της ελαχιστοποίησης δεδομένων (data minimization), οι οποίες επιβάλλουν στον μηχανικό λογισμικού να περιορίζει τη συλλογή και την επεξεργασία των PII στο ελάχιστο απαραίτητο βαθμό, μειώνοντας δραστικά την επιφάνεια επίθεσης και τον όγκο των πληροφοριών που θα μπορούσαν να υποκλαπούν σε περίπτωση μόλυνσης της συσκευής [39]. Παράλληλα, ο περιορισμός χρήσης, διακράτησης και κοινοποίησης (use, retention and disclosure limitation) διασφαλίζει ότι τα δεδομένα διαγράφονται αυτόματα μόλις εκπληρωθεί ο σκοπός τους και δεν εκτίθενται σε τρίτα μέρη, ενώ οι αρχές της ακρίβειας και ποιότητας (accuracy and quality) και της ανοικτότητας, διαφάνειας και ενημέρωσης (openness, transparency and notice) εγγυώνται την ακεραιότητα των δεδομένων και την πλήρη ορατότητα των διαδικασιών επεξεργασίας [40].

Η προστασία ολοκληρώνεται σε επίπεδο κώδικα μέσω των αρχών της συμμετοχής και πρόσβασης του υποκειμένου (individual participation and access) και της λογοδοσίας (accountability), οι οποίες συνδυάζονται άρρηκτα με την αρχή της ασφάλειας πληροφοριών (information security) για την επιβολή κρυπτογραφικών ελέγχων, και την αρχή της συμμόρφωσης με την ιδιωτικότητα (privacy compliance) που επαληθεύει τη συνολική ανθεκτικότητα του συστήματος [41].

3.5 Μηχανική απαιτήσεων και αρχιτεκτονικός σχεδιασμός: Η ενσωμάτωση της ιδιωτικότητας από τον σχεδιασμό (Privacy by Design)

Η αποτελεσματική προστασία ενός πληροφοριακού συστήματος από προηγμένες απειλές, όπως τα κατασκοπευτικά λογισμικά, δεν επιτυγχάνεται με την κατασταλτική προσθήκη μέτρων ασφαλείας μετά την ολοκλήρωση της ανάπτυξης. Αντιθέτως, απαιτεί την υιοθέτηση της αρχιτεκτονικής προσέγγισης «Ιδιωτικότητα από

τον Σχεδιασμό» (Privacy by Design-PbD), η οποία επιβάλλει την ενσωμάτωση των απαιτήσεων ιδιωτικότητας σε κάθε φάση του κύκλου ζωής ανάπτυξης λογισμικού (Software Development Life Cycle-SDLC). Όπως υπογραμμίζεται στο πλαίσιο ISO/IEC 29100, η διαδικασία αυτή μεταφράζει τις θεωρητικές αρχές σε χειροπιαστές «απαιτήσεις διασφάλισης της ιδιωτικότητας» (Privacy safeguarding requirements), οι οποίες πρέπει να αντιμετωπίζονται από τους μηχανικούς ως πρωταρχικοί αντικειμενικοί στόχοι ελέγχου (Control objectives) της αρχιτεκτονικής [26].

Στο πλαίσιο της μηχανικής απαιτήσεων, η μεθοδολογία αυτή επιβάλλει τον σχεδιασμό του συστήματος με την παραδοχή της μηδενικής εμπιστοσύνης (Zero Trust). Οι έλεγχοι ιδιωτικότητας (Privacy controls) δεν αντιμετωπίζονται απλώς ως νομικές υποχρεώσεις, αλλά ως αυστηροί τεχνικοί, οργανωτικοί και διαδικαστικοί περιορισμοί που επιβάλλονται στην ίδια την υποδομή των τεχνολογιών πληροφοριών και επικοινωνιών (ICT) [21]. Πρακτικά, αυτό σημαίνει ότι κατά τη φάση του αρχιτεκτονικού σχεδιασμού, οι μηχανικοί πρέπει να μοντελοποιούν τις ροές των δεδομένων με τέτοιο τρόπο ώστε η πρόσβαση στις προσωπικά αναγνωρίσιμες πληροφορίες (PII) να είναι εξ αρχής περιορισμένη (Privacy by Default) [42].

Η ενσωμάτωση της ιδιωτικότητας στον σχεδιασμό λειτουργεί ως οργανικός φραγμός κατά των spyware. Ακόμη και στην περίπτωση επιτυχούς παραβίασης της περιμέτρου ασφαλείας, μια σωστά σχεδιασμένη αρχιτεκτονική -η οποία έχει υλοποιήσει τον έλεγχο των κινδύνων (privacy risk management) από τα πρώτα στάδια της ανάλυσης [27] - εγγυάται ότι τα δεδομένα είναι είτε κρυπτογραφημένα, είτε κατακερματισμένα, είτε μη προσβάσιμα λόγω αυστηρών ρόλων, καθιστώντας τα υποκλαπέντα PII πρακτικά άχρηστα για τον εισβολέα. Με αυτόν τον τρόπο, το πλαίσιο ISO 29100 λειτουργεί ως ο θεμέλιος λίθος πάνω στον οποίο χτίζονται ανθεκτικές εφαρμογές, προστατεύοντας με συνέπεια τα δικαιώματα του υποκειμένου [43].

4. Το χάσμα μεταξύ νομικού πλαισίου και τεχνολογικής πραγματικότητας

4.1 Τα όρια του Ευρωπαϊκού Δικαίου (GDPR) απέναντι στα State-Sponsored Spyware

Η ραγδαία εξέλιξη και η διάθεση εξελιγμένων τεχνολογιών εμπορικού κατασκοπευτικού λογισμικού έχουν αναδείξει μια εμφανή ανισορροπία μεταξύ των υφιστάμενων κανονιστικών μηχανισμών και της ψηφιακής πραγματικότητας. Στο επίκεντρο της ευρωπαϊκής νομοθεσίας για την προστασία της ιδιωτικότητας βρίσκεται ο Γενικός Κανονισμός για την Προστασία Δεδομένων (GDPR), ο οποίος σχεδιάστηκε με σκοπό να θέσει ένα αυστηρό πλαίσιο διακυβέρνησης των προσωπικών δεδομένων (PII). Παρά το γεγονός ότι ο κανονισμός αυτός αναγνωρίζει ρητά πως οι πρακτικές παρακολούθησης μέσω κατασκοπευτικών λογισμικών παραβιάζουν θεμελιωδώς το δικαίωμα στην ιδιωτικότητα, η πρακτική του εφαρμογή συναντά ανυπέρβλητα δομικά και δικαιοδοτικά όρια όταν καλείται να αντιμετωπίσει επιθέσεις που ενορχηστρώνονται από κρατικούς δρώντες (state-sponsored actors) μέσω εργαλείων όπως το Pegasus ή το Predator [44].

Όπως τεκμηριώνεται στην ακαδημαϊκή βιβλιογραφία, λογισμικά όπως το Pegasus παραβιάζουν τόσο τις εθνικές όσο και τις διεθνείς νομοθεσίες προστασίας δεδομένων, καθώς λειτουργούν στερούμενα πλήρως την ενημερωμένη συγκατάθεση (informed consent) των χρηστών [44]. Τα εργαλεία αυτά αποκτούν ολοκληρωτική πρόσβαση στα προσωπικά δεδομένα χωρίς την παραμικρή πρότερη ενημέρωση ή έγκριση των υποκειμένων, αφαιρώντας τους ουσιαστικά το δικαίωμα της ενημερωμένης απόφασης σχετικά με τη διαχείριση της ιδιωτικής τους σφαίρας.

Ο GDPR ρυθμίζει κυρίως τις δραστηριότητες εμπορικών οντοτήτων και οργανισμών, αλλά εξαιρεί ρητά από το πεδίο εφαρμογής του τις δραστηριότητες που αφορούν την εθνική ασφάλεια και τη δημόσια τάξη, οι οποίες εμπίπτουν στην αποκλειστική αρμοδιότητα των κρατών μελών. Οι κρατικές υπηρεσίες πληροφοριών εκμεταλλεύονται αυτή τη θεσμική γκρίζα ζώνη, επικαλούμενες το απόρρητο της εθνικής ασφάλειας για να νομιμοποιήσουν τη χρήση εργαλείων μαζικής ή στοχευμένης

παρακολούθησης. Κατά συνέπεια, οι εποπτικές αρχές προστασίας δεδομένων στερούνται της δικαιοδοσίας να ελέγξουν ή να επιβάλλουν κυρώσεις σε κρατικές δομές που χρησιμοποιούν spyware, καθιστώντας τα δικαιώματα των υποκειμένων, όπως το δικαίωμα στην ενημέρωση ή τη διαγραφή, πρακτικά ανενεργά.

Επιπλέον, οι μηχανισμοί του GDPR βασίζονται στην αρχή της διαφάνειας και της λογοδοσίας των υπευθύνων επεξεργασίας, προϋποθέτοντας ότι ο χρήστης γνωρίζει ή μπορεί να ανακαλύψει ποιος επεξεργάζεται τα δεδομένα του. Η αρχιτεκτονική του state-sponsored spyware, από την άλλη, στηρίζεται στο αντίθετο. Οι zero-click επιθέσεις εκτελούνται στο παρασκήνιο χωρίς καμία ένδειξη, ενώ οι υποδομές Command and Control χρησιμοποιούν πολλαπλά επίπεδα proxy και εικονικών εταιρειών για να κρύψουν την ταυτότητα του τελικού χρήστη. Αυτή η ασυμμετρία πληροφορίας καθιστά αδύνατη τη στοιχειοθέτηση νομικής ευθύνης, καθώς το θύμα αδυνατεί να αποδείξει ποια κρατική οντότητα ή ποιος μεσάζων παραβίασε τη συσκευή του.

4.1.1 Νομικά κενά και γκρίζες ζώνες στη διάθεση κατασκοπευτικού λογισμικού

Το χάσμα μεταξύ της νομοθεσίας και της τεχνολογικής πραγματικότητας διευρύνεται περαιτέρω από τη γενικευμένη αβεβαιότητα που επικρατεί σε διεθνές επίπεδο σχετικά με το κατά πόσο η διεθνής νομοθεσία καταδικάζει ρητά και αποτελεσματικά τα κατασκοπευτικά λογισμικά [45]. Στην παρούσα φάση, δεν υφίστανται σαφή και καθολικά όρια όσον αφορά τη νομιμότητα της ανάπτυξης, της εμπορίας και της χρήσης αυτών των εργαλείων, γεγονός που επιτρέπει σε διακρατικό επίπεδο την άσκηση ψηφιακής κατασκοπείας εις βάρος διαφόρων ομάδων χωρίς ουσιαστικές νομικές επιπτώσεις.

Μέσα σε αυτό το καθεστώς διεθνούς νομοθετικού κενού, εταιρείες που αναπτύσσουν αυτά τα λογισμικά, όπως η NSO Group και η Intellexa, λειτουργούν με μεγάλη ευελιξία. Αν και οι οντότητες αυτές υποστηρίζουν ότι πωλούν τις τεχνολογίες τους αποκλειστικά σε νόμιμες κυβερνήσεις για την καταπολέμηση του σοβαρού εγκλήματος και της τρομοκρατίας, η ερευνητική δημοσιογραφία και η ψηφιακή δικανική ανάλυση έχουν αποδείξει ότι τα εργαλεία αυτά χρησιμοποιούνται

συστηματικά για την καταστολή της πολιτικής διαφωνίας [46].

Οι δημιουργοί spyware έχουν τη δυνατότητα να μεταφέρουν τις εταιρικές τους έδρες ή να χρησιμοποιούν πολύπλοκα δίκτυα θυγατρικών εταιρειών σε χώρες με εξαιρετικά χαλαρό κανονιστικό πλαίσιο, παρακάμπτοντας με ευκολία τους γεωγραφικούς περιορισμούς. Η παντελής έλλειψη ενός καθολικού, δεσμευτικού διεθνούς δικαίου για το κυβερνοέγκλημα επιτρέπει τη συνέχιση αυτού του διακρατικού εμπορίου, μετατρέποντας την ιδιωτικότητα σε μια θεωρητική έννοια που καταλύεται εύκολα στην πράξη από την τεχνολογική υπεροχή των επιτιθέμενων. Αν και έχουν γίνει προσπάθειες ελέγχου μέσω του Ευρωπαϊκού Κανονισμού Διπλής Χρήσης (Dual-Use Regulation) για την εξαγωγή ευαίσθητων εργαλείων, ή μέσω της ένταξης κατασκευαστών όπως η NSO Group στη Μαύρη Λίστα (Entity List) των ΗΠΑ, τα νομικά αυτά εργαλεία παρουσιάζουν εγγενείς αδυναμίες, ειδικά όσον αφορά τις ενδοευρωπαϊκές μεταφορές τεχνολογίας και τη δράση θυγατρικών εταιρικών σχημάτων [47].

4.2 Η ανάγκη τεχνολογικής (και όχι μόνο νομικής) θωράκισης του λογισμικού

Η αποτυχία των νομικών πλαισίων να αναχαιτίσουν τη διάδοση και τη χρήση του κατασκοπευτικού λογισμικού καταδεικνύει ότι ο νόμος δεν μπορεί να αποτελέσει τη μοναδική γραμμή άμυνας στην ψηφιακή εποχή. Η νομική προσφυγή ή η επιβολή προστίμων εκ των υστέρων δεν μπορούν ούτε να αποτρέψουν τη διαρροή ευαίσθητων δεδομένων (PII) ούτε να αποκαταστήσουν την παραβιασμένη ασφάλεια μιας συσκευής. Για τον λόγο αυτό, ανακύπτει η επιτακτική ανάγκη για μια ριζική μετατόπιση του ενδιαφέροντος προς την τεχνολογική θωράκιση του ίδιου του λογισμικού, μετατρέποντας τις αρχές της ιδιωτικότητας από νομικές επιταγές σε δομικά, αρχιτεκτονικά συστατικά των πληροφοριακών συστημάτων.

Η προσέγγιση αυτή ευθυγραμμίζεται απόλυτα με τη φιλοσοφία του προτύπου ISO/IEC 29100, το οποίο εισάγει την έννοια της ιδιωτικότητας από τον σχεδιασμό (privacy by design). Η βασική παραδοχή της τεχνολογικής θωράκισης είναι ότι το λογισμικό πρέπει να σχεδιάζεται με την προοπτική ότι το υποκείμενο περιβάλλον

εκτέλεσης ή το δίκτυο είναι εκ φύσεως εχθρικά (zero-trust architecture). Όπως καταδεικνύεται στην ακόλουθη ανάλυση της επίθεσης FORCEDENTRY, οι επιτιθέμενοι εκμεταλλεύονται την τυφλή εμπιστοσύνη που δείχνουν οι εφαρμογές σε αυτοματοποιημένες ροές δεδομένων. Η τεχνολογική απάντηση σε αυτό το πρόβλημα δεν είναι η απαγόρευση της χρήσης του λογισμικού μέσω νόμων, αλλά ο περιορισμός της επιφάνειας επίθεσης (attack surface) μέσω αυστηρών προγραμματιστικών προτύπων.

Η ενσωμάτωση Τεχνολογιών Ενίσχυσης Ιδιωτικότητας (PETs) σε επίπεδο πηγαίου κώδικα αποτελεί το πρακτικό μέσο για την επίτευξη αυτής της θωράκισης. Η χρήση κρυπτογραφικών πρωτοκόλλων που εξασφαλίζουν την απόκρυψη των μεταδεδωμένων, η επιβολή περιορισμών μνήμης μέσω της χρήσης γλωσσών προγραμματισμού με εγγενή ασφάλεια (memory-safe languages) και η απομόνωση των κρίσιμων διεργασιών σε επίπεδο υλικού, αποτελούν τα πραγματικά αναγκαία αντίμετρα.

Συμπερασματικά, η τεχνολογική θωράκιση του λογισμικού δεν έρχεται να αντικαταστήσει το δίκαιο, αλλά να του προσφέρει τα απαραίτητα εργαλεία υλοποίησης. Για να είναι αποτελεσματικός ο GDPR ή οποιοδήποτε άλλο κανονιστικό πλαίσιο, πρέπει να υποστηρίζεται από συστήματα που εφαρμόζουν τις νομικές αρχές με αυτοματοποιημένο και απαραβίαστο τρόπο. Μόνο μέσω της σύγκλισης της νομικής επιστήμης με τη μηχανική λογισμικού και τα διεθνή πρότυπα ασφαλείας, όπως το ISO/IEC 29100, μπορεί να γεφυρωθεί το χάσμα μεταξύ της θεωρίας και της τεχνολογικής πραγματικότητας, δημιουργώντας μια ουσιαστική ασπίδα προστασίας απέναντι στις σύγχρονες κυβερνοαπειλές.

5. Μελέτη Περίπτωσης 1-Ανάλυση ευπαθειών και επανασχεδιασμός πλατφορμών μηνυμάτων (iMessage/FORCEDENTRY)

5.1 Περιγραφή σεναρίου και ανατομία της επίθεσης FORCEDENTRY

5.1.1 Ιστορικό υπόβαθρο και η εξέλιξη των zero-click επιθέσεων της NSO Group

Η εμφάνιση των επιθέσεων μηδενικού κλικ (zero-click exploits) αντιπροσωπεύει τη σημαντικότερη ποιοτική μεταβολή στην αρχιτεκτονική του κατασκοπευτικού λογισμικού (spyware). Ιστορικά, η εταιρεία NSO Group είχε επενδύσει στην εκμετάλλευση ευπαθειών που απαιτούσαν τη διάδραση του χρήστη, κυρίως μέσω στοχευμένων μηνυμάτων spear-phishing. Ωστόσο, η σταδιακή εκπαίδευση των χρηστών σε θέματα κυβερνοασφάλειας ανάγκασε τους δημιουργούς spyware να αναπτύξουν τεχνικές που παρακάμπτουν πλήρως την ανθρώπινη συμπεριφορά.

Μια από τις πρώτες μαζικές καταγραφές αυτής της μετάβασης σημειώθηκε το 2019 στην πλατφόρμα WhatsApp. Σύμφωνα με το National Vulnerability Database και το αναγνωριστικό CVE-2019-3568, εντοπίστηκε μια κρίσιμη ευπάθεια buffer overflow στο WhatsApp VOIP stack. Η ευπάθεια αυτή επέτρεπε RCE επιθέσεις στις συσκευές-στόχους, αποστέλλοντας ένα ειδικά διαμορφωμένο πακέτο δεδομένων μέσω κλήσης, χωρίς το θύμα να χρειαστεί καν να απαντήσει.

Στη συνέχεια, το 2020, το ερευνητικό εργαστήριο «The Citizen Lab» του Πανεπιστημίου του Τορόντο ανακάλυψε ένα νέο zero-click exploit με όνομα KISMET. Βάσει των ευρημάτων του εργαστηρίου [46], η NSO Group χρησιμοποίησε το KISMET για να παγιδεύσει τις προσωπικές συσκευές τουλάχιστον τριάντα έξι δημοσιογράφων, ανταποκριτών και παραγωγών του ειδησεογραφικού δικτύου Al Jazeera, οι οποίες έτρεχαν λειτουργικό σύστημα iOS 13.5.1 ή παλαιότερο. Η συγκεκριμένη επίθεση βασιζόταν σε ευπάθειες zero-day της υποδομής iMessage της Apple, αποδεικνύοντας ότι οι ενσωματωμένες εφαρμογές συνομιλιών των

λειτουργικών συστημάτων αποτελούσαν πλέον το κύριο σημείο εισόδου για το κατασκοπευτικό λογισμικό Pegasus.

5.1.2 Η ανακάλυψη και το πλαίσιο της επίθεσης FORCEDENTRY

Η κορυφαία και τεχνικά πιο εξελιγμένη επίθεση zero-click καταγράφηκε το 2021 με την ονομασία FORCEDENTRY. Η ανακάλυψη του συγκεκριμένου exploit έγινε από το Citizen Lab κατά τη διάρκεια εξέτασης της συσκευής ενός Σαουδάραβα ακτιβιστή, ο οποίος υποψιαζόταν ότι είχε στοχοποιηθεί από κρατικούς φορείς μέσω του λογισμικού Pegasus της NSO Group [48]. Η ιχνηλάτηση των αρχείων του συστήματος της συσκευής αποκάλυψε τεκμήρια που ήταν απόλυτα χαρακτηριστικά της μεθοδολογίας της συγκεκριμένης εταιρείας, σύμφωνα με το εργαστήριο, επιβεβαιώνοντας την παγίδευση.

Τα στοιχεία αυτά περιλάμβαναν τη χαρακτηριστική δομή και μορφή των κακόβουλων απεσταλμένων αρχείων, καθώς και μια μη ολοκληρωμένη εκκαθάριση ενός εσωτερικού πίνακα του αρχείου DataUsage.sqlite. Οι επιτιθέμενοι είχαν προσπαθήσει να διαγράψουν τα ίχνη της μόλυνσης από τα αρχεία καταγραφής του συστήματος, ωστόσο η διαδικασία απέτυχε να εκκαθαρίσει τις αντίστοιχες εγγραφές του πίνακα ZLIVEUSAGE οι οποίες κάνουν αναφορά στα διαγραφμένα δεδομένα του πίνακα ZPROCESS. Τα συγκεκριμένα ψηφιακά αποτυπώματα έχουν πλέον συσχετιστεί με τη δράση της NSO.

Η παραβίαση αυτή βρισκόταν σε ισχύ τουλάχιστον από τον Φεβρουάριο του 2021. Στις 7 Σεπτεμβρίου 2021, το Citizen Lab παρέδωσε όλα τα ψηφιακά τεκμήρια στην Apple, η οποία στις 13 Σεπτεμβρίου επιβεβαίωσε την ύπαρξη του exploit και εξέδωσε μια επείγουσα ενημέρωση ασφαλείας για το καταναλωτικό κοινό. Η σοβαρότητα του περιστατικού οδήγησε την Apple στην απόφαση να καταθέσει επίσημη μήνυση κατά της NSO Group τον Νοέμβριο του 2021, επιδιώκοντας τον μόνιμο δικαστικό αποκλεισμό της εταιρείας από το οικοσύστημα και τις υπηρεσίες της [49].

5.1.3 Τεχνική ανάλυση και ανατομία του CVE-2021-30860

Η ευπάθεια έλαβε το επίσημο αναγνωριστικό CVE-2021-30860 από τον οργανισμό NIST και ταξινομήθηκε ως μια ευπάθεια integer overflow εξαιρετικά υψηλής κρισιμότητας [50]. Η αδυναμία εντοπίστηκε στη βιβλιοθήκη απόδοσης εικόνων του iOS, και συγκεκριμένα στη διαδρομή διαχείρισης αρχείων συνημμένων, η οποία ορίζεται ως Library/SMS/Attachments. Όταν ένας χρήστης λαμβάνει ένα αρχείο εικόνας μέσω της υπηρεσίας iMessage, το λειτουργικό σύστημα ενεργοποιεί αυτόματα μια διεργασία παρασκηνίου με την ονομασία IMTranscoderAgent. Η διεργασία αυτή είναι υπεύθυνη για την αυτόματη δημιουργία προεπισκόπησης και τη διαχείριση του αρχείου, προτού ο χρήστης αλληλεπιδράσει με την οθόνη ή ανοίξει το μήνυμα.

Οι επιτιθέμενοι εκμεταλλεύτηκαν αυτή την αυτοματοποιημένη ροή εργασίας εφαρμόζοντας μια σειρά από εξαιρετικά εξελιγμένες τεχνικές. Αρχικά, πραγματοποίησαν παραποίηση του τύπου αρχείου, αποστέλλοντας στη συσκευή-στόχο συνολικά 27 αρχεία .gif. Η εξέταση των magic bytes των αρχείων έδειξε ότι τέσσερα από αυτά δεν ήταν εικόνες, αλλά αρχεία PDF που περιείχαν κωδικοποιημένες ροές δεδομένων κατά το παλαιό πρότυπο συμπίεσης JBIG2. Ο ενσωματωμένος αποκωδικοποιητής JBIG2 του iOS, ο οποίος χρησιμοποιούνταν για την επεξεργασία του κειμένου που είχε υποστεί σάρωση μέσα στο PDF, περιείχε μια δομική αδυναμία ελέγχου των ορίων των μεταβλητών. Κατά την επεξεργασία ειδικά διαμορφωμένων κακόβουλων εντολών, προκλήθηκε το integer overflow, το οποίο επέτρεψε στους επιτιθέμενους να αποκτήσουν πρόσβαση σε αυθαίρετες διευθύνσεις μνήμης και να προκαλέσουν αλλοίωση του heap.

Με ένα εντυπωσιακό δείγμα reverse engineering, οι σχεδιαστές του Pegasus χρησιμοποίησαν τις βασικές λογικές εντολές του αποκωδικοποιητή JBIG2 για να υλοποιήσουν πύλες λογικής, όπως AND, OR και XOR, μέσα στην ίδια τη μνήμη. Με τον τρόπο αυτό, κατάφεραν να στήσουν έναν αυτόνομο υπολογιστή μέσα στο memory space της βιβλιοθήκης του iOS, εκτελώντας τον κακόβουλο κώδικα χωρίς να χρειάζεται να καλέσουν τις επίσημες συναρτήσεις του λειτουργικού συστήματος. Ειδικότερα, η συγκεκριμένη αλυσίδα εκμετάλλευσης προσομοίωσε μια Αριθμητική και Λογική Μονάδα (Arithmetic Logic Unit - ALU) 16-bit, δημιουργώντας ουσιαστικά μια πλήρη Εικονική Μηχανή (Virtual Machine) στο εσωτερικό του image parser. Το

γεγονός αυτό επέτρεψε την ολοκληρωτική παράκαμψη του μηχανισμού απομόνωσης BlastDoor της Apple και την εκτέλεση κώδικα (RCE) απευθείας στον δαίμονα IMTranscoderAgent [51].

5.2 Ανάλυση αποτυχίας των παραδοσιακών μηχανισμών ασφάλειας

Η επιτυχία του FORCEDENTRY κατέδειξε ότι οι κλασικοί μηχανισμοί άμυνας παρουσιάζουν δομικά κενά όταν αντιμετωπίζουν προηγμένες επίμονες απειλές. Όσον αφορά το iOS, βασίζεται στη φιλοσοφία του Sandboxing όπου κάθε εφαρμογή εκτελείται σε ένα απομονωμένο περιβάλλον, που δεν της επιτρέπει να έχει πρόσβαση στα αρχεία άλλων εφαρμογών ή στον πυρήνα του συστήματος. Στην περίπτωση του iMessage, η Apple είχε εισάγει ένα εξειδικευμένο sandbox με την ονομασία BlastDoor ακριβώς για να αναλύει τα μη έμπιστα δεδομένα σε απομονωμένο περιβάλλον.

Η επίθεση FORCEDENTRY κατάφερε να παρακάμψει το BlastDoor επειδή η ευπάθεια βρισκόταν στον κώδικα μιας core βιβλιοθήκης συστήματος, της CoreGraphics, η οποία διέθετε αυξημένα προνόμια. Με την επιτυχία της επίθεσης, διαθέτοντας πλέον τα δικαιώματα της ίδιας της διεργασίας IMTranscoderAgent, οι επιτιθέμενοι αποκτούσαν ανεμπόδιστη πρόσβαση στο σύστημα αρχείων, στα μηνύματα, στις κλήσεις και στα μεταδεδομένα της εκάστοτε συσκευής, προσπερνώντας τα τείχη του sandbox.

Παράλληλα, η επίθεση εξουδετέρωσε τον μηχανισμό ψηφιακής υπογραφής κώδικα (Code Signing). Ο μηχανισμός αυτός επιβάλλει τον αυστηρό κανόνα ότι κανένας κώδικας δεν μπορεί να εκτελεστεί στην κεντρική μονάδα επεξεργασίας αν δεν είναι ψηφιακά υπογεγραμμένος με ένα έγκυρο πιστοποιητικό της Apple. Το FORCEDENTRY δεν προσπάθησε να εισαγάγει ή να τρέξει ένα νέο, εξωτερικό εκτελέσιμο αρχείο, αλλά εκμεταλλεύτηκε τις εντολές που ήταν ήδη φορτωμένες στη RAM. Οι ήδη υπάρχουσες αυτές εντολές ήταν έμπιστες για το σύστημα αφού είχαν φορτωθεί τον νόμιμο και υπογεγραμμένο αποκωδικοποιητή JBIG2. Εφόσον η CPU εκτελούσε εντολές που ανήκαν σε ήδη εγκεκριμένο κώδικα της Apple, ο μηχανισμός Code Signing δεν εντόπισε καμία παραβίαση πολιτικής ασφάλειας.

Με την ίδια μεθοδολογία εξουδετερώθηκε και ο μηχανισμός ASLR, ο οποίος τυχαioποιεί τις θέσεις μνήμης που φορτώνονται τα κρίσιμα στοιχεία του συστήματος για να αποτρέψει την πρόβλεψη της θέσης τους από έναν επιτιθέμενο. Λόγω της φύσης του JBIG2 script, οι επιτιθέμενοι πραγματοποίησαν μια τεχνική γνωστή ως heap spraying, διάβασαν τις σχετικές διευθύνσεις και υπολόγισαν τις μετατοπίσεις σε πραγματικό χρόνο, παρακάμπτοντας και την προστασία της τυχαioποίησης.

5.3 Δομικές αναβαθμίσεις ασφαλείας στο iOS 15 και η συσχέτισή τους με το ISO/IEC 29100 και PETs

Η αντιμετώπιση κρίσιμων απειλών μηδενικού κλικ, όπως η επίθεση FORCEDENTRY, ανάγκασε τη βιομηχανία λογισμικού να μετατοπιστεί από την απλή έκδοση διορθωτικών πακέτων κώδικα (reactive patching) προς έναν πιο ριζικό και δομικό ανασχεδιασμό των συστημάτων της. Με την κυκλοφορία του iOS 15, η Apple εισήγαγε μια σειρά από νέες προστασίες ασφαλείας, οι οποίες περιελάμβαναν σημαντικές αναβαθμίσεις του μηχανισμού BlastDoor (Apple, 2021). Σύμφωνα με την επίσημη θέση της εταιρείας, ενώ το κατασκοπευτικό λογισμικό της NSO Group συνεχίζει να εξελίσσεται, δεν παρατηρήθηκαν στοιχεία επιτυχών απομακρυσμένων επιθέσεων σε συσκευές που εκτελούν το iOS 15 και μεταγενέστερες εκδόσεις, γεγονός που αναδεικνύει την αναγκαιότητα της θωράκισης του λογισμικού σε επίπεδο θεμελιώδους αρχιτεκτονικής [49].

Οι συγκεκριμένες τεχνικές παρεμβάσεις της Apple δεν αποτελούν απλώς απομονωμένα μέτρα ασφαλείας, αλλά συνδέονται άρρηκτα με το διεθνές πρότυπο ISO/IEC 29100 και τις Τεχνολογίες Ενίσχυσης Ιδιωτικότητας (PETs). Η ριζική αναδόμηση του iMessage για την επεξεργασία untrusted δεδομένων υλοποιεί στην πράξη την Αρχή της Ασφάλειας των Δεδομένων (Information Security) του ISO/IEC 29100. Το πρότυπο ορίζει ότι η προστασία των προσωπικών δεδομένων (PII) εξαρτάται άμεσα από τον έλεγχο και τον περιορισμό των προνομίων των διεργασιών. Με την ενίσχυση του BlastDoor στο iOS 15, η Apple επέβαλε αυστηρότερους περιορισμούς στο sandbox, διασφαλίζοντας ότι ακόμα και αν ένας parser υποστεί integer overflow, η διεργασία στερείται οποιασδήποτε πρόσβασης σε ευρύτερα αρχεία του συστήματος

ή σε δεδομένα ταυτοποίησης του χρήστη, εφαρμόζοντας έτσι ένα μοντέλο zero-trust σε επίπεδο κώδικα.

Παράλληλα, οι αλλαγές αυτές ενσωματώνουν τη βασική φιλοσοφία των Τεχνολογιών Ενίσχυσης Ιδιωτικότητας (PETs), εστιάζοντας στην απομόνωση της μνήμης και στην προγραμματιστική ασφάλεια. Η ανάγκη προστασίας από τεχνικές Data-Oriented Programming, οι οποίες χρησιμοποιήθηκαν στο FORCEDENTRY για την παράκαμψη του Code Signing, οδήγησε στην αξιοποίηση Αξιόπιστων Περιβαλλόντων Εκτέλεσης (Trusted Execution Environments) σε επίπεδο υλικού, όπως το Secure Enclave, για τον έλεγχο ευαίσθητων λειτουργιών. Επιπλέον, η σταδιακή αντικατάσταση παλαιών parser βιβλιοθηκών, που ήταν γραμμένες σε γλώσσες όπως η C++, με σύγχρονες γλώσσες που διαθέτουν εγγενή ασφάλεια μνήμης (memory-safe languages), όπως η Swift και η Rust, εξαλείφει πλήρως τη δυνατότητα εκδήλωσης buffer ή integer overflows κατά τη μεταγλώττιση.

Συνεπώς, η αρχιτεκτονική στροφή της Apple στο iOS 15 αποδεικνύει ότι η αποτελεσματική άμυνα απέναντι σε εμπορικά spyware απαιτεί την οργανική ενσωμάτωση των αρχών ιδιωτικότητας από τον σχεδιασμό (privacy by design), καθιστώντας τα τεχνολογικά πρότυπα και τις κρυπτογραφικές PETs το μοναδικό βιώσιμο δίκτυ ασφαλείας για τη διασφάλιση των επικοινωνιών.

6. Μελέτη περίπτωσης 2-Ανάπτυξη ηλεκτρονικού φακέλου υγείας (EHR)

6.1 Σχεδιασμός πληροφοριακού συστήματος υγείας έναντι προηγμένων απειλών (zero-click spyware)

Η ανάπτυξη και διαχείριση ενός Ηλεκτρονικού Φακέλου Υγείας (Electronic Health Record-EHR) αποτελεί μια από τις μεγαλύτερες προκλήσεις της σύγχρονης μηχανικής λογισμικού, καθώς προϋποθέτει τη διαχείριση εξαιρετικά ευαίσθητων προσωπικών δεδομένων (PII). Σε συνέχεια της αναδρομικής τεχνικής ανάλυσης του Κεφαλαίου 5, η οποία κατέδειξε πώς ένα live περιστατικό (FORCEDENTRY) μπορεί να εξουδετερώσει πλήρως την ασφάλεια μιας συσκευής σε επίπεδο λειτουργικού συστήματος, το παρόν Case Study μετατοπίζει την εστίαση στην προληπτική αρχιτεκτονική θωράκιση. Έχοντας ως δεδομένο (Zero Trust) ότι οι τερματικές συσκευές του ιατρικού προσωπικού είναι εκτεθειμένες σε αόρατες zero-click (Pegasus) ή 1-click (Predator) απειλές, ο σχεδιασμός ενός πληροφοριακού συστήματος υγείας απαιτεί μια νέα προσέγγιση. Αντί για την παραδοσιακή περιμετρική ασφάλεια και τις μαζικές επιθέσεις τύπου ransomware που απλώς «κλειδώνουν» υποδομές, τα σύγχρονα κατασκοπευτικά λογισμικά επιβάλλουν την ενσωμάτωση της ιδιωτικότητας στην ίδια τη ροή του κώδικα και των δεδομένων, ώστε να αποτραπεί η σιωπηλή εξόρυξη των PII.

Ένα ρεαλιστικό σενάριο αφορά τη χρήση zero-click spyware (όπως το Pegasus ή το Predator) εναντίον προσώπων-κλειδιών μέσα στο νοσοκομείο, όπως ένας γιατρός ή ένας διαχειριστής του συστήματος. Η μόλυνση της προσωπικής ή εταιρικής συσκευής του στόχου μπορεί να υλοποιηθεί με δύο διαφορετικούς φορείς επίθεσης: είτε μέσω αόρατων zero-click επιθέσεων (όπως το Pegasus), το οποίο εκμεταλλεύεται άγνωστες ευπάθειες σε εφαρμογές μηνυμάτων (π.χ. iMessage) χωρίς καμία αλληλεπίδραση του χρήστη, είτε μέσω εξελιγμένου spear-phishing (επιθέσεις 1-click, όπως το Predator), όπου ο ιατρός ξεγελιέται για να πατήσει έναν φαινομενικά νόμιμο σύνδεσμο μέσω SMS ή Viber. Όταν ο ιατρός συνδεθεί νομίμως στο πληροφοριακό σύστημα του νοσοκομείου, το spyware υποκλέπτει τα διαπιστευτήρια πρόσβασής του. Το αποτέλεσμα είναι η σιωπηλή και διαρκής εξόρυξη ιατρικών δεδομένων

στοχευμένων ασθενών, παρακάμπτοντας πλήρως τα ακριβά συστήματα περιμετρικής ασφάλειας (firewalls) του νοσοκομείου, τα οποία θεωρούν την κίνηση ως «νόμιμη».

Για την ολιστική αντιμετώπιση αυτής της ασύμμετρης απειλής, ο αρχιτεκτονικός σχεδιασμός του συστήματος υγείας δεν μπορεί να βασίζεται αποκλειστικά στην ασφάλεια των υποδομών, αλλά πρέπει να ενσωματώσει οργανικά την προστασία της ιδιωτικότητας των υποκειμένων. Αυτό επιτυγχάνεται με την εγκαθίδρυση ενός συστήματος διαχείρισης ιδιωτικότητας πληροφοριών (Privacy Information Management System-PIMS) [52].

Σύμφωνα με το διεθνές πρότυπο ISO/IEC 27701, ένα τέτοιο σύστημα λειτουργεί ως φυσική επέκταση των παραδοσιακών συστημάτων διαχείρισης ασφάλειας πληροφοριών, παρέχοντας τις απαιτήσεις και τις κατευθυντήριες γραμμές τόσο για την κυβερνοασφάλεια όσο και για την προστασία της ιδιωτικότητας των δεδομένων [53]. Βάσει αυτού του πλαισίου, το σύστημα eHealth σχεδιάζεται με την παραδοχή της μηδενικής εμπιστοσύνης (Zero Trust). Ο σχεδιασμός θεωρεί δεδομένο ότι η συσκευή του τελικού χρήστη (ιατρού) μπορεί να είναι ήδη αθόρυβα μολυσμένη από κάποιο spyware. Επομένως, το βάρος της προστασίας μετατοπίζεται από την περίμετρο στο ίδιο το δεδομένο, επιβάλλοντας ελέγχους ιδιωτικότητας σε επίπεδο εφαρμογής (application layer) και βάσης δεδομένων, ώστε να αποτραπεί η κλιμάκωση της επίθεσης και η μαζική διαρροή του ηλεκτρονικού φακέλου υγείας.

6.2 Μοντελοποίηση ρόλων, δικαιωμάτων πρόσβασης (RBAC) και περιορισμός σκοπού βάσει ISO 29100

Ο ακρογωνιαίος λίθος για την αποτροπή της μαζικής υποκλοπής δεδομένων από ένα μολυσμένο τερματικό είναι η αυστηρή εφαρμογή του μοντέλου ελέγχου πρόσβασης βάσει ρόλων (Role-Based Access Control-RBAC). Για την άντληση ενός ρεαλιστικού και τεχνολογικά ώριμου παραδείγματος, η παρούσα μελέτη εξετάζει το θεσμικό και τεχνικό πλαίσιο του Χονγκ Κονγκ, το οποίο αποτελεί έναν από τους πιο προηγμένους ψηφιακούς κόμβους παγκοσμίως. Στο πλαίσιο αυτής της εθνικής υποδομής υγείας, η συλλογή, η ανταλλαγή, η χρήση και η διαφύλαξη των ηλεκτρονικών φακέλων υγείας (EHR) περιορίζεται αυστηρά και αποκλειστικά σε συγκεκριμένους, θεσμοθετημένους σκοπούς που σχετίζονται με την παροχή

υγειονομικής φροντίδας [54]. Η προσέγγιση αυτή υλοποιεί την αρχή των ελάχιστων προνομίων, καθώς η νομοθεσία επιβάλλει τη δημιουργία μιας ολοκληρωμένης πληροφοριακής υποδομής, η οποία επιτρέπει στους παρόχους υγείας (ιατρούς και επαγγελματίες υγείας) να έχουν ελεγχόμενη πρόσβαση στις πληροφορίες μόνο κατόπιν ρητής συγκατάθεσης του ασθενούς [55].

Για την αποτελεσματική άμυνα έναντι εξελιγμένων κατασκοπευτικών απειλών, είτε πρόκειται για μηδενικής αλληλεπίδρασης (Pegasus) είτε για επιθέσεις κοινωνικής μηχανικής (Predator), η υποδομή του EHR δεν αντιμετωπίζει τους χρήστες ως μια ενιαία μάζα. Αντιθέτως, επιβάλλει περιορισμούς πρόσβασης με βάση την «ανάγκη γνώσης» (need-to-know basis) και τις έξι θεμελιώδεις Αρχές Προστασίας Δεδομένων (Data Protection Principles-DPPs) που διέπουν τη διαχείριση των PII [56]. Πρακτικά, ένας θεράπων ιατρός εξουσιοδοτείται να έχει πρόσβαση μόνο στο κλινικό ιστορικό των συγκεκριμένων ασθενών που τελούν υπό τη φροντίδα του, ενώ το διοικητικό προσωπικό περιορίζεται σε δεδομένα ταυτοποίησης ή τιμολόγησης.

Εάν ένα spyware μολύνει τη συσκευή ενός χρήστη, ο επιτιθέμενος εγκλωβίζεται μέσα στα αυστηρά όρια του συγκεκριμένου ρόλου και αδυνατεί να πραγματοποιήσει οριζόντια μετακίνηση (lateral movement) στη βάση δεδομένων. Σε απόλυτη αρμονία με τις αρχές της ελαχιστοποίησης δεδομένων και του περιορισμού σκοπού του προτύπου ISO 29100, η αρχιτεκτονική αυτή αποτρέπει την καθολική υποκλοπή των PII, διασφαλίζοντας ότι η παραβίαση ενός τερματικού δεν θα οδηγήσει σε κατάρρευση της ιδιωτικότητας ολόκληρου του νοσοκομειακού οργανισμού.

6.3 Ενσωμάτωση τεχνολογιών ενίσχυσης ιδιωτικότητας (PETs) και απο-ταυτοποίηση δεδομένων (de-identification)

Ακόμη και με την αυστηρή εφαρμογή του ελέγχου πρόσβασης (RBAC), μια εξελιγμένη κυβερνοεπίθεση με κατασκοπευτικό λογισμικό ενδέχεται να θέσει σε κίνδυνο τα διαπιστευτήρια ενός διαχειριστή συστήματος (system administrator), παρακάμπτοντας τους περιορισμούς των απλών ρόλων. Για να αποτραπεί η άμεση συσχέτιση των ασθενών σε περίπτωση μαζικής υποκλοπής της βάσης δεδομένων του ηλεκτρονικού φακέλου υγείας (EHR), η έσχατη γραμμή άμυνας είναι η ενσωμάτωση

τεχνολογιών ενίσχυσης ιδιωτικότητας (Privacy-Enhancing Technologies-PETs) στο επίπεδο της αρχιτεκτονικής του κώδικα.

Το πλαίσιο ISO/IEC 27701 επιβάλλει στις οργανώσεις να καθορίζουν σαφείς στόχους ελαχιστοποίησης των δεδομένων και να τεκμηριώνουν τους τεχνικούς μηχανισμούς που χρησιμοποιούν για την επίτευξη αυτού του σκοπού, όπως είναι η απο-ταυτοποίηση (de-identification) [57]. Στην πράξη, κατά τον σχεδιασμό του πληροφοριακού συστήματος, οι μηχανικοί λογισμικού οφείλουν να εφαρμόζουν τεχνικές ψευδωνυμοποίησης. Σε αυτή την αρχιτεκτονική, τα άμεσα αναγνωριστικά στοιχεία των ασθενών (όπως το ονοματεπώνυμο ή οι κρατικοί αναγνωριστικοί αριθμοί ταυτότητας) διαχωρίζονται από τα ιατρικά δεδομένα (διαγνώσεις, κλινικές σημειώσεις, θεραπείες) και αντικαθίστανται από ένα τυχαίο ψευδώνυμο (token). Με αυτόν τον τρόπο, διασφαλίζεται ότι οι μηχανισμοί και οι τεχνικές επεξεργασίας επιτυγχάνουν πλήρως τους στόχους ελαχιστοποίησης των προσωπικά αναγνωρίσιμων πληροφοριών (PII) [58].

Σε περίπτωση που ένα κατασκοπευτικό λογισμικό καταφέρει να εξάγει τον πίνακα με τα κλινικά δεδομένα, αυτά καθίστανται πρακτικά άχρηστα για τον επιτιθέμενο, καθώς στερούνται νοήματος χωρίς τον ξεχωριστό, αυστηρά προστατευμένο και κρυπτογραφημένο πίνακα που συσχετίζει τα ψευδώνυμα με τα πραγματικά πρόσωπα. Επιπρόσθετα, για δεδομένα που προορίζονται για δευτερογενή χρήση, όπως η στατιστική ανάλυση ή η ιατρική έρευνα, το σύστημα πρέπει να τα ανωνυμοποιεί πλήρως. Όπως ορίζει το πρότυπο ISO 27701, τα δεδομένα πρέπει να μετατρέπονται σε μια μορφή που δεν επιτρέπει σε καμία περίπτωση την ταυτοποίηση ή την επανα-ταυτοποίηση (re-identification) των υποκειμένων [59]. Η προσέγγιση αυτή εκμηδενίζει την εμπορική ή κατασκοπευτική αξία των υποκλαπέντων αρχείων, προστατεύοντας αποτελεσματικά την ιδιωτικότητα των ασθενών.

7. Συμπεράσματα

7.1 Προκλήσεις στην πρακτική εφαρμογή των προτύπων ιδιωτικότητας έναντι του εμπορικού κατασκοπευτικού λογισμικού

Η πρακτική ενσωμάτωση των διεθνών προτύπων ιδιωτικότητας (ISO/IEC 29100 και ISO/IEC 27701) στον κύκλο ζωής ανάπτυξης λογισμικού (SDLC) αντιμετωπίζει σύνθετες προκλήσεις, οι οποίες πηγάζουν άμεσα από τη ριζική μεταβολή του τοπίου των απειλών. Όπως τεκμηριώθηκε στα Κεφάλαια 1 και 2, η μετάβαση από τα απλά adware εμπορικής παρακολούθησης στα εξελεγμένα, κρατικού επιπέδου μισθοφορικά spyware (mercenary/state-sponsored spyware), όπως το Pegasus και το Predator, έχει ανατρέψει τα δεδομένα της παραδοσιακής ασφάλειας. Η μεγαλύτερη πρόκληση έγκειται στην τεχνική ασυμμετρία: η άμυνα καλείται να εφαρμόσει στατικά πλαίσια ελέγχων (privacy controls) απέναντι σε δυναμικές αλυσίδες εκμετάλλευσης (exploit chains) που δρουν αόρατα.

Η ανάλυση των μηχανισμών μόλυνσης ανέδειξε ότι οι zero-click επιθέσεις και οι προηγμένες τεχνικές anti-forensics (όπως η εκτέλεση αποκλειστικά στη μνήμη RAM-memory-only και οι μηχανισμοί αυτοκαταστροφής) εκμηδενίζουν την αποτελεσματικότητα των εκ των υστέρων ελέγχων και των παραδοσιακών logs. Όταν μια πλατφόρμα, όπως το iMessage στην επίθεση FORCEDENTRY (Κεφάλαιο 5), παραβιάζεται στον πυρήνα της λόγω εγγενών αδυναμιών διαχείρισης μνήμης, η εφαρμογή των αρχών του ISO 29100 καθίσταται εξαιρετικά δυσχερής. Οι μηχανικοί λογισμικού έρχονται αντιμέτωποι με το παράδοξο να πρέπει να εγγυηθούν την ιδιωτικότητα σε ένα περιβάλλον εκτέλεσης (OS kernel) που θεωρείται ήδη μολυσμένο και εχθρικό, γεγονός που επιβάλλει τη μετατόπιση των ελέγχων από το επίπεδο της συσκευής στο επίπεδο της αρχιτεκτονικής της ίδιας της εφαρμογής, όπως εφαρμόστηκε στο πληροφοριακό σύστημα EHR (κεφάλαιο 6).

7.2 Ανακεφαλαίωση και μελλοντικές κατευθύνσεις στην τεχνολογία λογισμικού

Ανακεφαλαιώνοντας, η παρούσα έρευνα κατέδειξε ότι η απλή νομική συμμόρφωση (π.χ. GDPR) ή η παθητική έκδοση διορθωτικών πακέτων κώδικα (reactive patching) είναι ανεπαρκείς για την αναχαιτίση εξελιγμένων απειλών. Η βιομηχανία εξαναγκάζεται σε μια ριζική αλλαγή υποδείγματος (paradigm shift). Η live αποτυχία των κλασικών αμυνών, όπως αναλύθηκε στο iMessage (κεφάλαιο 5), αποτελεί το ισχυρότερο τεχνολογικό κίνητρο για την υιοθέτηση των οργανικών αρχών της «Ιδιωτικότητας από τον Σχεδιασμό» (Privacy by Design), οι οποίες εφαρμόστηκαν στην αρχιτεκτονική του ηλεκτρονικού φακέλου υγείας (κεφάλαιο 6).

Ως προς τις μελλοντικές κατευθύνσεις, η τεχνολογία λογισμικού οφείλει να ενσωματώσει τις απαιτήσεις διασφάλισης της ιδιωτικότητας ως πρωταρχικούς αντικειμενικούς στόχους ελέγχου από τα πρώτα στάδια της μηχανικής απαιτήσεων. Η τάση της βιομηχανίας στρέφεται πλέον προς:

- Τη συστηματική χρήση γλωσσών προγραμματισμού με εγγενή ασφάλεια μνήμης (memory-safe languages). Η σταδιακή αντικατάσταση παραδοσιακών γλωσσών από σύγχρονα περιβάλλοντα, όπως η Rust και η Swift, κρίνεται επιβεβλημένη στον πυρήνα των κρίσιμων βιβλιοθηκών. Η προσέγγιση αυτή επιτρέπει την εξάλειψη ευπαθειών τύπου integer και buffer overflow ή heap corruption κατά τη φάση της μεταγλώττισης (compile-time), εμποδίζοντας τη δημιουργία αυθαίρετων εικονικών μηχανών εκτέλεσης (ALU emulations) εντός των parsers συστήματος.
- Την αξιοποίηση αξιόπιστων περιβαλλόντων εκτέλεσης (Trusted Execution Environments-TEEs). Η μετακίνηση κρίσιμων διεργασιών επεξεργασίας δεδομένων σε απομονωμένα περιβάλλοντα σε επίπεδο υλικού (hardware-level isolation) διασφαλίζει ότι, ακόμη και αν το λειτουργικό σύστημα παραβιαστεί ολικά, τα κρυπτογραφικά κλειδιά και τα ευαίσθητα PII παραμένουν προστατευμένα μέσα σε ασφαλείς θύλακες (enclaves).
- Την ενσωμάτωση προηγμένων κρυπτογραφικών PETs και αρχιτεκτονικής μικροϋπηρεσιών (microservices). Ο πλήρης αρχιτεκτονικός διαχωρισμός των πινάκων ταυτοποίησης από τα καθαυτό δεδομένα περιεχομένου (π.χ. κλινικές πληροφορίες), σε συνδυασμό με τεχνικές ομοιομορφικής κρυπτογράφησης, επιτρέπει τη διενέργεια στατιστικών ή επιχειρησιακών υπολογισμών επί

κρυπτογραφημένων αρχείων, εκμηδενίζοντας την αξία της πληροφορίας σε περίπτωση μαζικής υποκλοπής της βάσης.

- Την αντιμετώπιση του «Παραδόξου της Τεχνητής Νοημοσύνης» (AI Paradox) και των προκλήσεων του «Vibe Coding». Η ενσωμάτωση των μοντέλων Τεχνητής Νοημοσύνης στη μηχανική λογισμικού δημιουργεί μια διττή ασυμμετρία. Ενώ τα εργαλεία αυτά ενισχύουν τις αμυντικές δυνατότητες, ταυτόχρονα εξοπλίζουν τους επιτιθέμενους με αυτοματοποιημένους μηχανισμούς παραγωγής πολυμορφικού κατασκοπευτικού λογισμικού (polymorphic spyware), το οποίο μεταβάλλει συνεχώς τη δομή του για να αποφύγει τον εντοπισμό [60]. Παράλληλα, η ανάδυση του «Vibe Coding» - όπου η ανάπτυξη λογισμικού βασίζεται στην παραγωγή κώδικα μέσω φυσικής γλώσσας και prompts- καταρρίπτει το τεχνικό φράγμα εισόδου [60]. Το γεγονός αυτό επιτρέπει σε επιτιθέμενους με περιορισμένες γνώσεις να συνθέτουν σύνθετες και στοχευμένες αλυσίδες εκμετάλλευσης, καθιστώντας τις παραδοσιακές μεθόδους ανίχνευσης βάσει στατικών υπογραφών (signature-based detection) πλήρως παρωχημένες και επιβάλλοντας τη στροφή σε δυναμικά, συμπεριφορικά αντίμετρα [60].

Συμπερασματικά, απέναντι στην ασύμμετρη απειλή των spyware, το λογισμικό δεν αρκεί απλώς να λειτουργεί σωστά· πρέπει να σχεδιάζεται με την παραδοχή ότι η παραβίαση της συσκευής ή του λειτουργικού συστήματος είναι αναπόφευκτη, διασφαλίζοντας αρχιτεκτονικά και μαθηματικά ότι τα ευαίσθητα δεδομένα του οργανισμού και των χρηστών θα παραμείνουν αδιαπραγμάτευτα προστατευμένα.

8. Βιβλιογραφία

Pegasus-Product Description (NSO)

- [12]: «We provides, as default, one year of maintenance, support and upgrades services. These services include: Maintenance and Support: We provides maintenance services and three-tier level support that includes: ■Tier-1: Standard system operations problems ■Tier-2: Proactive resolving of technical problems Remote assistance using remote desktop software and a Virtual Private Network (VPN) where requested. ■Tier-3: Bug fixing and system updates of substantial system malfunctions. Upgrades: We have releases major upgrades to the Pegasus system few times a year. Such upgrades usually include: New features, New devices/operating system support, Bugs fix.», σελ. 40.

Κατασκοπευτικό Λογισμικό-Spyware (Νικόλαος Α. Τσιρώνης)

- [5]: «Το κρισιμότερο εύρημα της συγκεκριμένης περιόδου, όντας ταυτόχρονα και η γέφυρα παρόντος και μέλλοντος, υπήρξε η ανακάλυψη του δικτύου Ghostnet. Πρόκειται για μια από τις πρώτες επιχειρήσεις κυβερνοκατασκοπείας ευρείας κλίμακας, η οποία δρούσε απαρατήρητη σε 103 χώρες και στοχοποιούσε πρόσωπα υψηλής πολιτικής σημασίας...σηματοδοτώντας την μετάβαση από το οικονομικό έγκλημα στην ψηφιακή επιτήρηση», σελ. 18.
- [60]: «Το AI Paradox αναφέρεται στο φαινόμενο πως τα εργαλεία που χρησιμοποιούνται για την καταπολέμηση των επιθέσεων και την ανίχνευση μοτίβων, αποτελούν ταυτόχρονα τον ισχυρότερο σύμμαχο των επιτιθέμενων...η χρήση του Polymorphic Spyware από τους επιτιθέμενους δυσχεραίνει τον εντοπισμό του κακόβουλου κώδικα...Η τάση ανάπτυξης λογισμικού μέσω prompts παρουσιάζει δύο κύριες απειλές. Αρχικά, το φράγμα εισόδου για την δημιουργία κακόβουλων λογισμικών καταρρίπτεται...Επιπλέον, η παραδοσιακή ανίχνευση βάσει υπογραφών αποδυναμώνεται», σελ. 39-40.

Spyware Technologies: Technical Analysis, Detection and Countermeasures (Pappas Nikolaos)

- [3]: «More complex types, like Pegasus or Predator, are sophisticated tools sometimes called state grade spyware-these programs get around encrypted messaging applications; they also use zero day flaws.», σελ 15.
- [4]: «A device does not show any signs when these programs operate...The program accesses the microphone, camera, or screen. It also tracks the person's location.», σελ 15.
- [9]: «Avanced spyware software also use exploit chains - these chains consist of a series of software flaws linked together to obtain total access to a device. They often target mobile operating systems like iOS or Android, so attackers can get around common security measures such as sandboxing or code signing.», σελ 18.
- [10]: «Zero-click attacks are hard to find and stop mainly because they leave little to no evidence. Forensic checks often uses indirect signs. These signs include odd system actions, strange data transfer and system anomalies.», σελ 19.
- [14]: «Encryption and Obfuscation: Spyware encrypts its communication plus hides its operations...Self-destruct mechanisms: Some spyware deletes itself or its logs if specific events occur, for example, if the SIM card changes or someone finds it... If Pegasus detects threat analysis tools or signs of forensic inspection, it can automatically: Erase itself, Delete related logs, Overwrite memory with null bytes [2]», σελ 26 και 30.
- [15]: «Sophisticated spyware, such as Pegasus and Predator are designed to operate invisibly. On that account, common antivirus software often does not find it. Finding this software requires forensic methods and special tools...Amnesty International developed Mobile Verification Toolkit (MVT). It is an open-source software that helps identify devices that are infected with Pegasus spyware. It works by: Analyzing encrypted iPhone backups, Search for known forensic traces such as suspicious domain/IP contact», σελ 25.
- [16]: «Forensic analysts examine: System logs...Network logs...Application behavior, such as unexpected battery drain or camera activation. Packet Capture and Traffic Analysis: Applications like Wireshark or tcpdump are used to monitor device traffic.», σελ 25-26.

- [47]: «In addition, the Dual-Use Regulation manages the export of sensitive tools, such as spyware, by requiring licenses...Outside the EU, the United States put NSO Group and other spyware sellers on its Entity List.», σελ. 54.
- [51]: «These segments implemented virtual logic gates to simulate a 16-bit arithmetic logic unit (ALU). To put it simply, it created a Virtual Machine inside the image parser», σελ. 28.

Click, Load, Kill: A Look into the Cyberweapon Industry in the WANA Region (SMEX)

- [18]: «When did you first notice things were wrong? What did you notice? What did you do at that point? ...Did you take any precautions online before this attack?», σελ. 108.

Πλαίσιο Ιδιωτικότητας (Privacy framework) ISO 29100:2011/2024 (Στέφανος Γκρίτζαλης)

- [7]: «Πλαίσιο Ιδιωτικότητας (Privacy framework) ISO 29100:2011/2024», σελ. 1.
- [22]: «PII» (αριστερή στήλη) και «Information Asset» (δεξιά στήλη), σελ. 126.
- [24]: «Privacy control» (αριστερή στήλη) και «Control» (δεξιά στήλη), σελ. 126.
- [25]: «Privacy breach» (αριστερή στήλη) και «Information Security incident» (δεξιά στήλη). Επίσης, πιο κάτω αναγράφει «Privacy risk» (αριστερή στήλη) και «Risk» (δεξιά στήλη), σελ. 126.
- [26]: «Privacy safeguarding requirements» (αριστερή στήλη) και «Control objectives» (δεξιά στήλη), σελ. 126.
- [27]: «Privacy risk management» (αριστερή στήλη) και «Risk management» (δεξιά στήλη), σελ. 126.
- [28]: «Αναγνωριστικά στοιχεία ταυτότητας (PII personally identifiable information)», σελ. 11.
- [30]: «Υποκείμενο των δεδομένων (PII principal)», «Φυσικό πρόσωπο με το οποίο σχετίζονται αναγνωριστικά στοιχεία», σελ. 12.

- [33]: «Δικαιούχος Ιδιωτικότητας (privacy stakeholder)», «Φυσικό ή νομικό πρόσωπο, δημόσια αρχή, οργανισμός ή άλλος φορέας που μπορεί να επηρεάσει, να επηρεαστεί ή θεωρεί ότι επηρεάζεται από απόφαση ή δραστηριότητα που σχετίζεται με αναγνωριστός ταυτότητας PII», σελ. 11.
- [34]: «Υπεύθυνος επεξεργασίας αναγνωριστικών στοιχείων ταυτότητας (PII controller)» «Δικαιούχος ιδιωτικότητας (privacy stakeholder) που προσδιορίζει τον σκοπό και τα μέσα για την επεξεργασία αναγνωριστικών στοιχείων ταυτότητας PII, διαφορετικός από φυσικά πρόσωπα που χρησιμοποιούν δεδομένα για προσωπικό σκοπό», σελ. 12.
- [37]: «5. Οι αρχές (principles) ιδιωτικότητας», σελ. 90.

ISO/IEC 29100 (2024)

- [23]: «natural person to whom the personally identifiable information (PII) (3.7) relates», σελ. 2.
- [29]: «information that (a) can be used to establish a link between the information and the natural person to whom such information relates, or (b) is or might be directly or indirectly linked to a natural person», σελ. 2.
- [31]: «To determine whether a PII principal is identifiable, account should be taken of all the means which can reasonably be used by the privacy stakeholder holding the data, or by any other party, to establish the link between the set of PII and the natural person.», σελ. 2.
- [32]: «The increasing commercial use and value of PII, the sharing of PII across jurisdictions, and the growing complexity of ICT systems, can make it difficult for an organization to ensure privacy and to achieve compliance with the various applicable laws.», σελ. v.
- [21]: «This document provides a high-level framework for the protection of personally identifiable information (PII) within information and communication technology (ICT) systems. It is general in nature and places organizational, technical, and procedural aspects in an overall privacy framework.», σελ. v.
- [35]: «privacy stakeholder that processes personally identifiable information (PII) (3.7) on behalf of and in accordance with the instructions of a PII controller (3.8)», σελ. 2.

- [36]: «privacy stakeholder (3.20) other than the personally identifiable information (PII) principal (3.9), the PII controller (3.8) and the PII processor (3.10), and the natural persons who are authorized to process the data under the direct authority of the PII controller or the PII processor», σελ. 4.
- [38]: «6.2 Consent and choice» «6.3 Purpose legitimacy and specification» «Adhering to the purpose legitimacy and specification principle involves: ensuring that the purpose(s) complies with applicable law and relies on a permissible legal basis;», σελ. 14-15.
- [39]: «6.4 Collection limitation: limiting the collection of PII to that which is within the bounds of applicable law and strictly necessary for the specified purpose(s). [...] 6.5 Data minimization: minimize the PII which is processed and the number of privacy stakeholders and people to whom PII is disclosed or who are allowed to process it;», σελ. 15.
- [40]: «6.6 Use, retention and disclosure limitation», «6.7 Accuracy and quality», «6.8 Openness, transparency and notice», σελ. 16.
- [41]: «6.9 Individual participation and access», «6.10 Accountability», «6.11 Information security», «6.12 Privacy compliance», σελ. 17-19.
- [42]: «6.5 Data minimization» «minimize the PII which is processed and the number of privacy stakeholders and people to whom PII is disclosed or who are allowed to process it;», σελ. 15.
- [43]: «The privacy framework is intended to help organizations define their privacy safeguarding requirements related to PII within an ICT environment», «Use of this document will: aid in the design, implementation, operation, and maintenance of ICT systems that handle and protect PII;», σελ. v.

ISO/IEC 27701 (2025)

- [52]: «This document specifies requirements for establishing, implementing, maintaining and continually improving a privacy information management system (PIMS).», σελ. 1.
- [53]: «This document enables an organization to align or integrate its privacy information management system (PIMS) with the requirements of other

management system standards, and in particular with the information security management system specified in ISO/IEC 27001.», σελ. vi.

- [57]: «The organization should define and document data minimization objectives and what mechanisms (such as de-identification) are used to meet those objectives.», σελ. 30.
- [58]: «In these cases, the organization should define and document the extent to which the PII should be associated with the PII principal, as well as the mechanisms and techniques designed to process PII, such that the de-identification and PII minimization objectives are achieved.», σελ. 30.
- [59]: «The organization should either delete PII or render it in a form which does not permit identification or re-identification of PII principals, as soon as the original PII is no longer necessary for the identified purpose(s).», σελ. 31.

Συμπληρωματικό υλικό

- [1] European Parliament (2023) The impact of Pegasus on fundamental rights and democratic processes. Brussels: European Parliament. Available at: [https://www.europarl.europa.eu/RegData/etudes/STUD/2022/740514/IPOL_STU\(2022\)740514_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/STUD/2022/740514/IPOL_STU(2022)740514_EN.pdf)
- [2] European Parliament Research Service (2023) Investigation of the use of Pegasus and equivalent surveillance spyware. Brussels: European Parliament. Available at: [https://www.europarl.europa.eu/RegData/etudes/ATAG/2023/747923/EPRS_AT_A\(2023\)747923_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/ATAG/2023/747923/EPRS_AT_A(2023)747923_EN.pdf)
- [6] European Parliament Think Tank (2024) What action has Parliament taken against spyware abuse? Available at: [What action has Parliament taken against spyware abuse? | Epthinktank](#)
- [19] European Data Protection Board (2020) Guidelines 4/2019 on Article 25 Data Protection by Design and by Default. Available at: [Guidelines 4/2019 on Article 25 Data Protection by Design and by Default](#)
- [20] European Commission (n.d.) What does data protection by design and by default mean? Available at: [What does data protection ‘by design’ and ‘by default’ mean? - European Commission](#)

- [8] ENISA (2024) ENISA Threat Landscape 2024. Available at: [ENISA Threat Landscape 2024](#)
- [11] Citizen Lab. Hide and Seek: Tracking NSO Group's Pegasus Spyware to Operations in 45 Countries. Available at: [HIDE AND SEEK: Tracking NSO Group's Pegasus Spyware to Operations in 45 Countries - The Citizen Lab](#)
- [13] Kaspersky. What commercial spyware is, and what different types there are. Kaspersky official blog. Available at: [What commercial spyware is, and what different types there are | Kaspersky official blog](#)
- [17] Cyber Forensic Academy. Best Network Forensic Tools for Packet & Log Analysis. Available at: https://www-cyberforensicacademy-com.translate.goog/blog/best-network-forensic-tools-for-packet-log-analysis?_x_tr_sl=en&_x_tr_tl=el&_x_tr_hl=el&_x_tr_pto=sge
- [44]: Kareem, K.M., 2024. A comprehensive analysis of pegasus spyware and its implications for digital privacy and security. arXiv preprint arXiv:2404.19677.
- [45]: Anstis, S., 2024. Regulating transnational dissident cyber espionage. International & Comparative Law Quarterly, 73(1), pp.259-274.
- [46]: Marczak, B., Scott-Railton, J., Al-Jizawi, S., Anstis, S. και Deibert, R., 2020. The Great iPwn: Journalists Hacked with Suspected NSO Group iMessage Zero-Click Exploit. The Citizen Lab. Available at: <https://citizenlab.ca/research/the-great-ipwn-journalists-hacked-with-suspected-nso-group-imessage-zero-click-exploit/>
- [48]: Marczak, B., Scott-Railton, J., McKune, S., Razzak, B. και Deibert, R., 2021. FORCEDENTRY: NSO Group iMessage Zero-Click Exploit Captured in the Wild. The Citizen Lab. Available at: <https://citizenlab.ca/research/forcedentry-nso-group-imessage-zero-click-exploit-captured-in-the-wild/>
- [49]: Apple, 2021. Apple sues NSO Group to curb the abuse of state-sponsored spyware. Apple Newsroom. Available at: <https://www.apple.com/sa/newsroom/2021/11/apple-sues-nso-group-to-curb-the-abuse-of-state-sponsored-spyware/>
- [50]: National Vulnerability Database (NVD), 2021. CVE-2021-30860 Detail. NIST. Available at: <https://nvd.nist.gov/vuln/detail/CVE-2021-30860>

- Personal Data (Privacy) Ordinance and Electronic Health System: Points to Note for Healthcare Providers and Healthcare Professionals [54-56]:
 - [54]: «The Electronic Health System Ordinance, Cap. 625 ("eHealth Ordinance") provides a legal basis for the collection, sharing, use, and safekeeping of patients' health data under the Electronic Health System ("eHealth System").», σελ. 2.
 - [55]: «The eHealth System is an information infrastructure for healthcare providers (including doctors and other healthcare professionals) in both the public and private sectors to, with the consent of a patient, access and share the patient's health record for healthcare-related purposes.», σελ. 2.
 - [56]: «Patients' health records in the eHealth System amount to personal data, which is protected under the Personal Data (Privacy) Ordinance, Cap. 486 ("PDPO"). Healthcare providers and the Commissioner for the Electronic Health Record, as data users, should act in accordance with the requirements under the eHealth Ordinance as well as the PDPO (including the Six Data Protection Principles ("DPPs"))», σελ. 2.
- Hong Kong Government, 2026. Electronic Health System Ordinance (Cap. 625). Consolidated version. Retrieved from <https://www.elegislation.gov.hk/hk/cap625!en>
- Admin. (2023, July 21). Enhancing Healthcare Data Security with Managed Services-EHR Role Based Access-Ellit Groups. Retrieved from <https://ellitgroups.com/enhancing-healthcare-data-security-with-managed-services-ehr-role-based-access/>
- Henry, K. (2026, March 16). Role-Based Access Control (RBAC) in healthcare: benefits, examples, and best practices. Retrieved from <https://www.accountablehq.com/post/role-based-access-control-rbac-in-healthcare-benefits-examples-and-best-practices>
- EHealth. (n.d.). Retrieved from <https://www.ehealth.gov.hk/en/whats-ehealth/access-control.html>

- National Vulnerability Database (NVD), 2019. CVE-2019-3568 Detail. NIST.
Available at: <https://nvd.nist.gov/vuln/detail/CVE-2019-3568>